



Federal Public Trust Device Certificate Policy

DRAFT

Version 0.1

September 2017

Table of Contents

1. INTRODUCTION	10
1.1 Overview	10
1.2 Document name and identification	11
1.2.1. Revisions	11
1.2.2. Relevant Dates	11
1.3 PKI Participants	11
1.3.1 Certification Authorities	12
1.3.2 Registration Authorities	12
1.3.3 Subscribers	12
1.3.4 Relying Parties	13
1.3.5 Other Participants	13
1.4 Certificate Usage	13
1.4.1 Appropriate Certificate Uses	13
1.4.2 Prohibited Certificate Uses	13
1.5 Policy administration	13
1.5.1 Organization Administering the Document	13
1.5.2 Contact Person	14
1.5.3 Person Determining CPS suitability for the policy	14
1.5.4 CPS approval procedures	14
1.6 Definitions and Acronyms	14
1.6.1 Definitions	14
1.6.2 Acronyms	21
1.6.3 References	22
1.6.4 Conventions	23
2. PUBLICATION AND REPOSITORY RESPONSIBILITIES	24
2.1 Repositories	24
2.2 Publication of information	24
2.3 Time or frequency of publication	25
2.4 Access controls on repositories	25
3. IDENTIFICATION AND AUTHENTICATION	26
3.1 Naming	26
3.1.1 Types of names	26
3.1.2 Need for names to be meaningful	26
3.1.3 Anonymity or pseudonymity of subscribers	26

3.1.4 Rules for interpreting various name forms	26
3.1.5 Uniqueness of names.....	26
3.1.6 Recognition, authentication, and role of trademarks.....	26
3.2 Initial identity validation	27
3.2.1 Method to prove possession of private key	27
3.2.2 Authentication of Organization and Domain Identity	27
3.2.3 Authentication of individual identity	32
3.2.4 Non-verified subscriber information.....	32
3.2.5 Validation of authority	32
3.2.6 Criteria for Interoperation or Certification	32
3.3 Identification and authentication for re-key requests.....	32
3.3.1 Identification and authentication for routine re-key.....	32
3.3.2 Identification and authentication for re-key after revocation.....	33
3.4 Identification and authentication for revocation request.....	33
4. CERTIFICATE LIFE-CYCLE OPERATIONAL REQUIREMENTS	34
4.1 Certificate Application.....	34
4.1.1 Who can submit a certificate application.....	34
4.1.2 Enrollment process and responsibilities	34
4.2 Certificate application processing.....	35
4.2.1 Performing identification and authentication functions	35
4.2.2 Approval or rejection of certificate applications.....	35
4.2.3 Time to process certificate applications	36
4.3 Certificate issuance	36
4.3.1 CA actions during certificate issuance	36
4.3.2 Notification to subscriber by the CA of issuance of certificate	36
4.4 Certificate acceptance	36
4.4.1 Conduct constituting certificate acceptance	36
4.4.2 Publication of the certificate by the CA	37
4.4.3 Notification of certificate issuance by the CA to other entities	37
4.5 Key pair and certificate usage	37
4.5.1 Subscriber private key and certificate usage.....	37
4.5.2 Relying party public key and certificate usage	37
4.6 Certificate renewal.....	37
4.6.1 Circumstance for certificate renewal.....	37
4.6.2 Who may request renewal	37
4.6.3 Processing certificate renewal requests	38

4.6.4 Notification of new certificate issuance to subscriber.....	38
4.6.5 Conduct constituting acceptance of a renewal certificate.....	38
4.6.6 Publication of the renewal certificate by the CA	38
4.6.7 Notification of certificate issuance by the CA to other entities	38
4.7 Certificate re-key	38
4.7.1 Circumstance for certificate re-key.....	38
4.7.2 Who may request certification of a new public key	38
4.7.3 Processing certificate re-keying requests.....	38
4.7.4 Notification of new certificate issuance to subscriber.....	38
4.7.5 Conduct constituting acceptance of a re-keyed certificate	39
4.7.6 Publication of the re-keyed certificate by the CA.....	39
4.7.7 Notification of certificate issuance by the CA to other entities	39
4.8 Certificate modification	39
4.8.1 Circumstance for certificate modification	39
4.8.2 Who may request certificate modification.....	39
4.8.3 Processing certificate modification requests.....	39
4.8.4 Notification of new certificate issuance to subscriber.....	39
4.8.5 Conduct constituting acceptance of modified certificate.....	39
4.8.6 Publication of the modified certificate by the CA.....	40
4.8.7 Notification of certificate issuance by the CA to other entities	40
4.9 Certificate revocation and suspension.....	40
4.9.1 Circumstances for revocation	40
4.9.2 Who can request revocation.....	41
4.9.3 Procedure for revocation request	41
4.9.4 Revocation request grace period	42
4.9.5 Time within which CA must process the revocation request.....	42
4.9.6 Revocation checking requirement for relying parties	42
4.9.7 CRL issuance frequency	42
4.9.8 Maximum latency for CRLs	43
4.9.9 On-line revocation/status checking availability	43
4.9.10 On-line revocation checking requirements	43
4.9.11 Other forms of revocation advertisements available	43
4.9.12 Special requirements re key compromise	43
4.9.13 Circumstances for suspension.....	44
4.9.14 Who can request suspension	44
4.9.15 Procedure for suspension request.....	44

4.9.16 Limits on suspension period	44
4.10 Certificate status services	44
4.10.1 Operational characteristics.....	44
4.10.2 Service availability	44
4.10.3 Optional features.....	44
4.11 End of subscription	44
4.12 Key escrow and recovery	45
4.12.1 Key escrow and recovery policy and practices	45
4.12.2 Session key encapsulation and recovery policy and practices	45
5. MANAGEMENT, OPERATIONAL, AND PHYSICAL CONTROLS.....	46
5.1 PHYSICAL SECURITY CONTROLS.....	46
5.1.1 Site location and construction.....	47
5.1.2 Physical access.....	47
5.1.3 Power and air conditioning.....	48
5.1.4 Water exposures.....	48
5.1.5 Fire prevention and protection	48
5.1.6 Media storage.....	48
5.1.7 Waste disposal	48
5.1.8 Off-site backup	48
5.2 Procedural controls	48
5.2.1 Trusted roles	48
5.2.2 Number of Individuals Required per Task	49
5.2.3 Identification and authentication for each role	50
5.2.4 Roles requiring separation of duties.....	50
5.3 Personnel controls.....	50
5.3.1 Qualifications, experience, and clearance requirements.....	50
5.3.2 Background check procedures	50
5.3.3 Training Requirements and Procedures.....	50
5.3.4 Retraining frequency and requirements.....	51
5.3.5 Job rotation frequency and sequence.....	51
5.3.6 Sanctions for unauthorized actions	51
5.3.7 Independent Contractor Controls	51
5.3.8 Documentation supplied to personnel	51
5.4 Audit logging procedures.....	51
5.4.1 Types of events recorded.....	51
5.4.2 Frequency for Processing and Archiving Audit Logs	52

5.4.3 Retention Period for Audit Logs.....	52
5.4.4 Protection of Audit Log.....	53
5.4.5 Audit Log Backup Procedures.....	53
5.4.6 Audit Log Accumulation System (internal vs. external).....	53
5.4.7 Notification to event-causing subject.....	53
5.4.8 Vulnerability assessments.....	53
5.5 Records archival	53
5.5.1 Types of records archived.....	54
5.5.2 Retention period for archive	54
5.5.3 Protection of archive	54
5.5.4 Archive backup procedures	55
5.5.5 Requirements for time-stamping of records	55
5.5.6 Archive collection system (internal or external).....	55
5.5.7 Procedures to obtain and verify archive information	55
5.6 Key changeover	55
5.7 Compromise and disaster recovery.....	55
5.7.1 Incident and compromise handling procedures.....	55
5.7.2 Recovery Procedures if Computing resources, software, and/or data are corrupted.....	58
5.7.3 Recovery Procedures after Key Compromise	58
5.7.4 Business continuity capabilities after a disaster.....	58
5.8 CA or RA termination.....	58
6. TECHNICAL SECURITY CONTROLS	60
6.1 Key pair generation and installation	60
6.1.1 Key pair generation.....	60
6.1.2 Private key delivery to subscriber	60
6.1.3 Public key delivery to certificate issuer.....	61
6.1.4 CA public key delivery to relying parties.....	61
6.1.5 Key sizes.....	61
6.1.6 Public key parameters generation and quality checking.....	62
6.1.7 Key usage purposes (as per X.509 v3 key usage field).....	62
6.2 Private Key Protection and Cryptographic Module Engineering Controls	62
6.2.1 Cryptographic module standards and controls.....	63
6.2.2 Private key (n out of m) multi-person control.....	63
6.2.3 Private key escrow	63
6.2.4 Private key backup	63
6.2.5 Private key archival.....	63

6.2.6 Private key transfer into or from a cryptographic module.....	64
6.2.7 Private key storage on cryptographic module.....	64
6.2.8 Activating Private Keys.....	64
6.2.9 Deactivating Private Keys	64
6.2.10 Destroying Private Keys.....	64
6.2.11 Cryptographic Module Capabilities	64
6.3 Other aspects of key pair management	64
6.3.1 Public key archival.....	64
6.3.2 Certificate operational periods and key pair usage periods	65
6.4 Activation data.....	65
6.4.1 Activation data generation and installation	65
6.4.2 Activation data protection	65
6.4.3 Other aspects of activation data	65
6.5 Computer security controls	65
6.5.1 Specific computer security technical requirements.....	65
6.5.2 Computer security rating.....	66
6.6 Life cycle technical controls.....	66
6.6.1 System development controls	66
6.6.2 Security management controls.....	66
6.6.3 Life cycle security controls.....	67
6.7 Network security controls	67
6.8 Time-stamping.....	68
7. CERTIFICATE, CRL, AND OCSP PROFILES.....	69
7.1 Certificate profile.....	69
7.1.1 Version number(s).....	69
7.1.2 Certificate Content and Extensions; Application of RFC 5280	69
7.1.3 Algorithm object identifiers.....	72
7.1.4 Name forms	72
7.1.5 Name constraints.....	74
7.1.6 Certificate policy object identifier	76
7.1.7 Usage of Policy Constraints extension	77
7.1.8 Policy qualifiers syntax and semantics.....	77
7.1.9 Processing semantics for the critical Certificate Policies extension	77
7.2 CRL profile	77
7.2.1 Version number(s).....	77
7.2.2 CRL and CRL entry extensions	77

7.3 OSCP profile	78
7.3.1 Version number(s).....	78
7.3.2 OSCP extensions.....	78
8. COMPLIANCE AUDIT AND OTHER ASSESSMENTS.....	80
8.1 Frequency or circumstances of assessment	80
8.2 Identity/qualifications of assessor	80
8.3 Assessor's relationship to assessed entity	81
8.4 Topics covered by assessment	81
8.5 Actions taken as a result of deficiency.....	81
8.6 Communication of results	81
8.7 Self-Audits	82
9. OTHER BUSINESS AND LEGAL MATTERS.....	83
9.1 Fees.....	83
9.1.1 Certificate issuance or renewal fees	83
9.1.2 Certificate access fees	83
9.1.3 Revocation or status information access fees	83
9.1.4 Fees for other services.....	83
9.1.5 Refund policy.....	83
9.2 Financial responsibility	83
9.2.1 Insurance coverage.....	83
9.2.2 Other assets	83
9.2.3 Insurance or warranty coverage for end-entities.....	83
9.3 Confidentiality of business information.....	83
9.3.1 Scope of confidential information.....	83
9.3.2 Information not within the scope of confidential information	83
9.3.3 Responsibility to protect confidential information.....	83
9.4 Privacy of personal information	83
9.4.1 Privacy plan	83
9.4.2 Information treated as private	83
9.4.3 Information not deemed private	84
9.4.4 Responsibility to protect private information	84
9.4.5 Notice and consent to use private information.....	84
9.4.6 Disclosure pursuant to judicial or administrative process	84
9.4.7 Other information disclosure circumstances.....	84
9.5 Intellectual property rights	84
9.6 Representations and warranties	84

9.6.1 CA representations and warranties.....	84
9.6.2 RA representations and warranties.....	85
9.6.3 Subscriber representations and warranties.....	85
9.6.4 Relying party representations and warranties	86
9.6.5 Representations and warranties of other participants	86
9.7 Disclaimers of warranties.....	86
9.8 Limitations of liability	86
9.9 Indemnities.....	87
9.10 Term and termination.....	87
9.10.1 Term	87
9.10.2 Termination.....	87
9.10.3 Effect of termination and survival.....	87
9.11 Individual notices and communications with participants	87
9.12 Amendments.....	87
9.12.1 Procedure for amendment.....	87
9.12.2 Notification mechanism and period	87
9.12.3 Circumstances under which OID must be changed.....	87
9.13 Dispute resolution provisions	87
9.14 Governing law	88
9.15 Compliance with applicable law.....	88
9.16 Miscellaneous provisions	88
9.16.1 Entire agreement	88
9.16.2 Assignment	88
9.16.3 Severability	88
9.16.4 Enforcement (attorneys' fees and waiver of rights)	88
9.16.5 Force Majeure	88
9.17 Other provisions	88

1. INTRODUCTION

1.1 Overview

This Certificate Policy (CP) outlines the policy and requirements for the U.S. Federal Public Key Infrastructure, and the issuance and management of U.S. Federal Publicly Trusted Device Certificates. The certificates under this policy are for identifying and authenticating government services. This policy incorporates Certificate Transparency as a key component in promoting publicly accessible and accountable services.

This document serves two purposes:

- to specify the Federal Public Device PKI Certificate Policy and requirements, and
- to provide requirements for what each Certification Authority must address in its Certification Practices Statement

This policy is for a hierarchical Public Key Infrastructure restricted to services operated by or on behalf of the U.S. Government and U.S. Federal entities. The hierarchical PKI is referenced as the **Federal Public Device PKI** in this document.

This policy and requirements are applicable to all Certification Authorities within a chain of trust under the **US Federal Device Root CA**. The requirements are to be flowed down from the Root Certification Authority through all Subordinate Certification Authorities.

The Federal Public Device PKI conforms to the Version 1.4.9 of the guidelines adopted by the Certification Authority/Browser Forum (“CA/Browser Forum”) when issuing publicly trusted certificates, including the Baseline Requirements for the Issuance and Management of Publicly Trusted Certificates (“Baseline Requirements”). This document is based on the CA/Browser Forum Baseline Requirements, which is licensed under the Creative Commons Attribution 4.0 International License. All additions and modifications made to create this document are in the public domain as works of the U.S. Government, and copyright and related rights in the work are waived.

Additional documents related to the Federal Public Device PKI, such as Certification Practices Statements, Audits, and Subscriber Agreement(s) can be found at <INSERT URL HERE>.

In accordance with RFC 3647, this CP includes all nine sections of the RFC 3647 framework and an additional addendum with the certificate profiles.

The terms and provisions of this certificate policy shall be interpreted under and governed by applicable Federal law.

The following Certification Authorities are covered under this CP:

CA Type	Distinguished Name	Key Pair Type and Parameters	SHA-256 Key Fingerprint	Validity Period
Root CA	<INSERT DN>	<INSERT RSA>	<INSERT SHA-256 FINGERPRINT>	<INSERT VALIDITY PERIOD>
Subordinate CA	<INSERT DN>	<INSERT RSA>	<INSERT SHA-256 FINGERPRINT>	<INSERT VALIDITY PERIOD>

1.2 Document name and identification

This is the Federal Public Device PKI Certificate Policy.

The following Certificate Policy identifiers are reserved for use by CAs as a means of asserting compliance with this CP:

OID Arc	Owner	OID	Description
2.16.840.1.101.3.2.1	NIST Computer Security Objects Register (CSOR), Public Key Infrastructure (PKI) Objects Registration	{joint-iso-itu-t(2) country(16) us(840) organization(1) gov(101) csor(3) pki(2) certificate-policies(1) } (2.16.840.1.101.3.2.1)	TBD
2.16.840.1.101.3.2.1	NIST Computer Security Objects Register (CSOR), Public Key Infrastructure (PKI) Objects Registration	{joint-iso-itu-t(2) country(16) us(840) organization(1) gov(101) csor(3) pki(2) certificate-policies(1) } (2.16.840.1.101.3.2.1)	TBD

1.2.1. Revisions

Ver.	Change Proposal	Description	Adopted	Effective*
1.0.0	<TBD>	Version 1.0 of the Certificate Policy Adopted	<TBD>	<TBD>

* Effective Date and Additionally Relevant Compliance Date(s)

1.2.2. Relevant Dates

Compliance	Section(s)	Summary Description (See Full Text for Details)
yyyy-mm-dd	<TBD>	Description

1.3 PKI Participants

The Federal Public Key Infrastructure Policy Authority (FPKIPA) is a sub-council comprised of U.S. Federal Government Agency representatives and is chartered by the U.S. Federal CIO Council. The FPKIPA manages this policy and represents the interests of the U.S. Federal CIOs and CISOs.

1.3.1 Certification Authorities

The Certification Authorities operated under this policy provide services to U.S. Federal Government entities which may be part of the Executive Branch, Legislative Branch and Judicial Branch of the Federal Government. The services are not provided to the general public, commercial entities, U.S. State, Local, Territorial, Native Sovereign Nations, or international government entities.

Certification Authority (CA) is defined in Section 1.6.

1.3.2 Registration Authorities

This Certificate Policy is focused on promoting automation, improving efficiencies, supporting operational security, and establishing trust in the U.S. Government and the digital services operated by or on behalf of U.S. Federal Government entities. The widespread adoption of practices and protocols to support automation in certificate management have been foundational to increases in the deployment of secure protocols for webservices.

While this policy promotes automation for the Certification Authorities, there still exists a need to allow a delegation of responsibility to U.S. Federal Government entities that form part of the U.S. Federal Government enterprise.

This policy allows for persons who may not be affiliated with the same organizational unit that is operating the Certificate Authority to assist in the certificate application process and be designated as Enterprise Registration Authorities as a role. Registration Authority system functions shall be the responsibility of the Certificate Authority.

A CA MAY designate an Enterprise Registration Authority (RA) to verify certificate requests from the Enterprise RA's affiliated U.S. Federal Government entity. The CA SHALL NOT accept certificate requests authorized by an Enterprise RA unless the following requirements are satisfied:

1. The CA SHALL confirm that the requested Fully-Qualified Domain Name(s) are within the Enterprise RA's verified Domain Namespace(s) as registered in the .GOV (DotGov) and .MIL (DotMil) gTLDs Domain Name Registrars.
2. The CA SHOULD confirm that the requested Fully-Qualified Domain Name(s) are not within any Domain Namespace(s) for any U.S. State, Local, Territorial, Native Sovereign Nations, or any other entities identified as a *Non-Federal Agency* in the DotGov Domain Name Registrar per United States Code (U.S.C.) 41 CFR Part 102-173.

The CA SHALL impose these limitations through an agreement with the Authorizing Authority of the Domain Name as defined under United States Code (U.S.C.) 41 CFR Part 102-173. The CA SHALL monitor compliance by the Enterprise RA and institute technical controls. The CA SHOULD use both audits and analytics based methods such as monitoring of Certificate Transparency Log(s) and services to ensure compliance.

Delegated Third Parties are not allowed under this policy.

1.3.3 Subscribers

As defined in Section 1.6.1.

1.3.4 Relying Parties

“Relying Party” and “Application Software Supplier” are defined in Section 1.6.1.

Relying Parties should verify the validity of certificates via revocation services provided for all certificates prior to relying on certificates. Certificate Revocation List (CRL) and On-line Certificate Status Protocol (OCSP) service location information is provided within certificates.

1.3.5 Other Participants

Not applicable.

1.4 Certificate Usage

1.4.1 Appropriate Certificate Uses

This Certificate Policy (CP) and requirements for U.S. Federal Government is limited to Publicly Trusted Device Certificates used for identifying and authenticating devices and services. Certificates may be used for all legal authentication and encryption purposes.

1.4.2 Prohibited Certificate Uses

Certificates may not be used where prohibited by law.

Certificates for identifying natural persons are not allowed under this policy and the Federal Public Device PKI, including but not limited to identity certificates used to identify natural persons for digital signatures, S/MIME, client authentication, and encryption. CAs may not issue Subscriber certificates for natural persons or enter into any cross-certification with any CAs that issue certificates used to identify and authenticate natural persons.

1.5 Policy administration

The Federal Public Key Infrastructure Policy Authority (FPKIPA) manages this policy and represents the interests of the U.S. Federal CIOs and CISOs.

1.5.1 Organization Administering the Document

The Federal Public Key Infrastructure Policy Authority (FPKIPA) is responsible for:

- Maintaining this CP, and
- Approving the CPS for each CA that issues certificates under this policy, and
- Approving the compliance audit report for each CA issuing certificates under this policy, and
- Ensuring continued conformance of each CA that issues certificates under this policy with applicable requirements as a condition for allowing continued participation, and
- Ensuring compliance with CA/Browser Forum Baseline Requirements, and

- Ensuring compliance with any trust store requirements and any browser requirements that the Federal Device Root pursues or has inclusion in.

1.5.2 Contact Person

Contact information for the Federal Public Key Infrastructure Policy Authority is fpki@gsa.gov.

1.5.3 Person Determining CPS suitability for the policy

Federal Public Key Infrastructure Policy Authority

1.5.4 CPS approval procedures

A CPS shall be submitted and approved by the Federal Public Key Infrastructure Policy Authority.

Prior to submitting a CPS, the CA shall commission a compliance analysis study culminating in a written report that provides a summary of areas in which the CPS may not or does not comply with this CP. The compliance analysis shall be performed by an independent party. The CA shall resolve these discrepancies prior to submitting the CPS to the Policy Authority. The CA must have an approved CPS and meet all CP and CPS requirements prior to commencing operations.

1.6 Definitions and Acronyms

1.6.1 Definitions

Affiliate: A corporation, partnership, joint venture or other entity controlling, controlled by, or under common control with another entity, or an agency, department, political subdivision, or any entity operating under the direct control of a Government Entity.

Air-Gapped: Certificate Systems or components that are physically and logically disconnected from the public internet.

Applicant: The natural person or Legal Entity that applies for (or seeks renewal of) a Certificate. Once the Certificate issues, the Applicant is referred to as the Subscriber. For Certificates issued to devices, the Applicant is the entity that controls or operates the device named in the Certificate, even if the device is sending the actual certificate request.

Applicant Representative: A natural person or human sponsor who is either the Applicant, employed by the Applicant, or an authorized agent who has express authority to represent the Applicant: (i) who signs and submits, or approves a certificate request on behalf of the Applicant, and/or (ii) who signs and submits a Subscriber Agreement on behalf of the Applicant, and/or (iii) who acknowledges the Terms of Use on behalf of the Applicant when the Applicant is an Affiliate of the CA or is the CA.

Application Software Supplier: A supplier of Internet browser software or other relying-party application software that displays or uses Certificates and incorporates Root Certificates.

Attestation Letter: A letter attesting that Subject Information is correct written by an accountant, lawyer, government official, or other reliable third party customarily relied upon for such information.

- 143 **Audit Period:** In a period-of-time audit, the period between the first day (start) and the last day of
144 operations (end) covered by the auditors in their engagement. (This is not the same as the period of time
145 when the auditors are on-site at the CA.) The coverage rules and maximum length of audit periods are
146 defined in section 8.1.
- 147 **Audit Report:** A report from a Qualified Auditor stating the Qualified Auditor's opinion on whether an
148 entity's processes and controls comply with the mandatory provisions of these Requirements.
- 149 **Authorization Domain Name:** The Domain Name used to obtain authorization for certificate issuance
150 for a given FQDN. The CA may use the FQDN returned from a DNS CNAME lookup as the FQDN for
151 the purposes of domain validation. If the FQDN contains a wildcard character, then the CA MUST
152 remove all wildcard labels from the left most portion of requested FQDN. The CA may prune zero or
153 more labels from left to right until encountering a Base Domain Name and may use any one of the
154 intermediate values for the purpose of domain validation.
- 155 **Authorized Port:** One of the following ports: 80 (http), 443 (https), 115 (sftp), 25 (smtp), 22 (ssh).
- 156 **Base Domain Name:** The portion of an applied-for FQDN that is the first domain name node left of a
157 registry-controlled or public suffix plus the registry-controlled or public suffix (e.g. "example.co.uk" or
158 "example.com"). For FQDNs where the right-most domain name node is a gTLD having ICANN
159 Specification 13 in its registry agreement, the gTLD itself may be used as the Base Domain Name.
- 160 **CAA:** From RFC 6844 (<http://tools.ietf.org/html/rfc6844>): "The Certification Authority Authorization
161 (CAA) DNS Resource Record allows a DNS domain name holder to specify the Certification Authorities
162 (CAs) authorized to issue certificates for that domain. Publication of CAA Resource Records allows a
163 public Certification Authority to implement additional controls to reduce the risk of unintended certificate
164 mis-issue."
- 165 **Certificate:** An electronic document that uses a digital signature to bind a public key and an identity.
- 166 **Certificate Data:** Certificate requests and data related thereto (whether obtained from the Applicant or
167 otherwise) in the CA's possession or control or to which the CA has access.
- 168 **Certificate Management Process:** Processes, practices, and procedures associated with the use of keys,
169 software, and hardware, by which the CA verifies Certificate Data, issues Certificates, maintains a
170 Repository, and revokes Certificates.
- 171 **Certificate Policy:** A set of rules that indicates the applicability of a named Certificate to a particular
172 community and/or PKI implementation with common security requirements.
- 173 **Certificate Problem Report:** Complaint of suspected Key Compromise, Certificate misuse, or other
174 types of fraud, compromise, misuse, or inappropriate conduct related to Certificates.
- 175 **Certificate Revocation List:** A regularly updated time-stamped list of revoked Certificates that is created
176 and digitally signed by the CA that issued the Certificates.
- 177 **Certificate System:** A system used by a CA or Delegated Third Party to process, approve issuance of, or
178 store certificates or certificate status information, including the database, database server, and storage.

- 179 **Certificate System Component:** A individual element of a larger Certificate System used to process,
180 approve issuance of, or store certificates or certificate status information. This includes the database,
181 database server, storage devices, certificate hosting services, registration authority systems, and any other
182 element used in certificate management.
- 183 **Certification Authority:** An organization that is responsible for the creation, issuance, revocation, and
184 management of Certificates. The term applies equally to both Roots CAs and Subordinate CAs.
- 185 **Certification Practice Statement:** One of several documents forming the governance framework in
186 which Certificates are created, issued, managed, and used.
- 187 **Certificate Transparency (CT):** Publicly operated record of certificate issuance.
- 188 **Control:** “Control” (and its correlative meanings, “controlled by” and “under common control with”)
189 means possession, directly or indirectly, of the power to: (1) direct the management, personnel, finances,
190 or plans of such entity; (2) control the election of a majority of the directors ; or (3) vote that portion of
191 voting shares required for “control” under the law of the entity’s Jurisdiction of Incorporation or
192 Registration but in no case less than 10%.
- 193 **Country:** Either a member of the United Nations OR a geographic region recognized as a Sovereign State
194 by at least two UN member nations.
- 195 **Cross Certificate:** A certificate that is used to establish a trust relationship between two Root CAs.
- 196 **CSPRNG:** A random number generator intended for use in cryptographic system.
- 197 **Delegated Third Party:** A natural person or Legal Entity that is not the CA but is authorized by the CA
198 to assist in the Certificate Management Process by performing or fulfilling one or more of the CA
199 requirements found herein.
- 200 **Domain Authorization Document:** Documentation provided by, or a CA’s documentation of a
201 communication with, a Domain Name Registrar, the Domain Name Registrant, or the person or entity
202 listed in WHOIS as the Domain Name Registrant (including any private, anonymous, or proxy
203 registration service) attesting to the authority of an Applicant to request a Certificate for a specific
204 Domain Namespace.
- 205 **Domain Contact:** The Domain Name Registrant, technical contact, or administrative contract (or the
206 equivalent under a ccTLD) as listed in the WHOIS record of the Base Domain Name or in a DNS SOA
207 record.
- 208 **Domain Name:** The label assigned to a node in the Domain Name System.
- 209 **Domain Namespace:** The set of all possible Domain Names that are subordinate to a single node in the
210 Domain Name System.
- 211 **Domain Name Registrant:** Sometimes referred to as the “owner” of a Domain Name, but more properly
212 the person(s) or entity(ies) registered with a Domain Name Registrar as having the right to control how a
213 Domain Name is used, such as the natural person or Legal Entity that is listed as the “Registrant” by
214 WHOIS or the Domain Name Registrar.

- 215 **Domain Name Registrar:** A person or entity that registers Domain Names under the auspices of or by
216 agreement with: (i) the Internet Corporation for Assigned Names and Numbers (ICANN), (ii) a national
217 Domain Name authority/registry, or (iii) a Network Information Center (including their affiliates,
218 contractors, delegates, successors, or assigns).
- 219 **Effective Date:** 1 July 2012.
- 220 **Embedded SCT:** An SCT delivered via an X.509v3 extension within the certificate.
- 221 **Enterprise RA:** An employee or agent of an organization unaffiliated with the CA who authorizes
222 issuance of Certificates to that organization.
- 223 **Expiry Date:** The “Not After” date in a Certificate that defines the end of a Certificate’s validity period.
- 224 **Fully-Qualified Domain Name:** A Domain Name that includes the labels of all superior nodes in the
225 Internet Domain Name System.
- 226 **Government Entity:** A government-operated legal entity, agency, department, ministry, branch, or
227 similar element of the government of a country, or political subdivision within such country (such as a
228 state, province, city, county, etc.).
- 229 **High Risk Certificate Request:** A Request that the CA flags for additional scrutiny by reference to
230 internal criteria and databases maintained by the CA, which may include names at higher risk for phishing
231 or other fraudulent usage, names contained in previously rejected certificate requests or revoked
232 Certificates, names listed on the Miller Smiles phishing list or the Google Safe Browsing list, or names
233 that the CA identifies using its own risk-mitigation criteria.
- 234 **High Security Zone:** An area (physical or logical) protected by physical and logical controls that
235 appropriately protect the confidentiality, integrity, and availability of the CA’s or Delegated Third Party
236 Private Key or cryptographic hardware.
- 237 **Internal Name:** A string of characters (not an IP address) in a Common Name or Subject Alternative
238 Name field of a Certificate that cannot be verified as globally unique within the public DNS at the time of
239 certificate issuance because it does not end with a Top Level Domain registered in IANA’s Root Zone
240 Database.
- 241 **Issuing CA:** In relation to a particular Certificate, the CA that issued the Certificate. This could be either
242 a Root CA or a Subordinate CA.
- 243 **Key Compromise:** A Private Key is said to be compromised if its value has been disclosed to an
244 unauthorized person, an unauthorized person has had access to it, or there exists a practical technique by
245 which an unauthorized person may discover its value. A Private Key is also considered compromised if
246 methods have been developed that can easily calculate it based on the Public Key (such as a Debian weak
247 key, see <http://wiki.debian.org/SSLkeys>) or if there is clear evidence that the specific method used to
248 generate the Private Key was flawed.
- 249 **Key Generation Script:** A documented plan of procedures for the generation of a CA Key Pair.
- 250 **Key Pair:** The Private Key and its associated Public Key.

- 251 **Legal Entity:** An association, corporation, partnership, proprietorship, trust, government entity or other
252 entity with legal standing in a country's legal system.
- 253 **Object Identifier:** A unique alphanumeric or numeric identifier registered under the International
254 Organization for Standardization's applicable standard for a specific object or object class.
- 255 **OCSP Responder:** An online server operated under the authority of the CA and connected to its
256 Repository for processing Certificate status requests. See also, Online Certificate Status Protocol.
- 257 **Offline:** An air-gapped Certificate System or component that is only turned on to conduct certificate
258 activity (i.e. issue / revoke a certificate, issue certificate revocation list, etc).
- 259 **Online:** Certificate Systems or components that are physically and logically connected to the public
260 and/or a private internet.
- 261 **Online Certificate Status Protocol:** An online Certificate-checking protocol that enables relying-party
262 application software to determine the status of an identified Certificate. See also OCSP Responder.
- 263 **Parent Company:** A company that Controls a Subsidiary Company.
- 264 **Private Key:** The key of a Key Pair that is kept secret by the holder of the Key Pair, and that is used to
265 create Digital Signatures and/or to decrypt electronic records or files that were encrypted with the
266 corresponding Public Key.
- 267 **Public Key:** The key of a Key Pair that may be publicly disclosed by the holder of the corresponding
268 Private Key and that is used by a Relying Party to verify Digital Signatures created with the holder's
269 corresponding Private Key and/or to encrypt messages so that they can be decrypted only with the
270 holder's corresponding Private Key.
- 271 **Public Key Infrastructure:** A set of hardware, software, people, procedures, rules, policies, and
272 obligations used to facilitate the trustworthy creation, issuance, management, and use of Certificates and
273 keys based on Public Key Cryptography.
- 274 **Publicly-Trusted Certificate:** A Certificate that is trusted by virtue of the fact that its corresponding
275 Root Certificate is distributed as a trust anchor in widely-available application software.
- 276 **Qualified Auditor:** A natural person or Legal Entity that meets the requirements of Section 8.3.
- 277 **Random Value:** A value specified by a CA to the Applicant that exhibits at least 112 bits of entropy.
- 278 **Registered Domain Name:** A Domain Name that has been registered with a Domain Name Registrar.
- 279 **Registration Authority (RA):** Any Legal Entity that is responsible for identification and authentication
280 of subjects of Certificates, but is not a CA, and hence does not sign or issue Certificates. An RA may
281 assist in the certificate application process or revocation process or both. When "RA" is used as an
282 adjective to describe a role or function, it does not necessarily imply a separate body, but can be part of
283 the CA.

284 **Reliable Data Source:** An identification document or source of data used to verify Subject Identity
285 Information that is generally recognized among commercial enterprises and governments as reliable, and
286 which was created by a third party for a purpose other than the Applicant obtaining a Certificate.

287 **Reliable Method of Communication:** A method of communication, such as a postal/courier delivery
288 address, telephone number, or email address, that was verified using a source other than the Applicant
289 Representative.

290 **Relying Party:** Any natural person or Legal Entity that relies on a Valid Certificate. An Application
291 Software Supplier is not considered a Relying Party when software distributed by such Supplier merely
292 displays information relating to a Certificate.

293 **Repository:** An online database containing publicly-disclosed PKI governance documents (such as
294 Certificate Policies and Certification Practice Statements) and Certificate status information, either in the
295 form of a CRL or an OCSP response.

296 **Request Token:** A value derived in a method specified by the CA which binds this demonstration of
297 control to the certificate request.

- 298 • The Request Token SHALL incorporate the key used in the certificate request.
- 299 • A Request Token MAY include a timestamp to indicate when it was created.
- 300 • A Request Token MAY include other information to ensure its uniqueness.
- 301 • A Request Token that includes a timestamp SHALL remain valid for no more than 30 days from
302 the time of creation.
- 303 • A Request Token that includes a timestamp SHALL be treated as invalid if its timestamp is in the
304 future.
- 305 • A Request Token that does not include a timestamp is valid for a single use and the CA SHALL
306 NOT re-use it for a subsequent validation.

307 The binding SHALL use a digital signature algorithm or a cryptographic hash algorithm at least as strong
308 as that to be used in signing the certificate request.

309 **Required Website Content:** Either a Random Value or a Request Token, together with additional
310 information that uniquely identifies the Subscriber, as specified by the CA.

311 **Requirements:** The Requirements found in this document.

312 **Reserved IP Address:** An IPv4 or IPv6 address that the IANA has marked as reserved:

313 <http://www.iana.org/assignments/ipv4-address-space/ipv4-address-space.xml>

314 <http://www.iana.org/assignments/ipv6-address-space/ipv6-address-space.xml>

315 **Root CA:** The top level Certification Authority whose Root Certificate is distributed by Application
316 Software Suppliers and that issues Subordinate CA Certificates.

317 **Root Certificate:** The self-signed Certificate issued by the Root CA to identify itself and to facilitate
318 verification of Certificates issued to its Subordinate CAs.

- 319 **Secure Zone:** An area (physical or logical) protected by physical and logical controls that appropriately
320 protect the confidentiality, integrity, and availability of Certificate Systems.
- 321 **Security Support Systems:** A system used to provide security support functions, such as authentication,
322 network boundary control, audit logging, audit log reduction and analysis, vulnerability scanning, and
323 anti-virus.
- 324 **Signed Certificate Timestamp (SCT):** A timestamp and promise from a Certificate Transparency
325 operator to add the submitted certificate to the log within a specified time period.
- 326 **Sovereign State:** A state or country that administers its own government, and is not dependent upon, or
327 subject to, another power.
- 328 **Subject:** The natural person, device, system, unit, or Legal Entity identified in a Certificate as the
329 Subject. The Subject is either the Subscriber or a device under the control and operation of the Subscriber.
- 330 **Subject Identity Information:** Information that identifies the Certificate Subject. Subject Identity
331 Information does not include a domain name listed in the subjectAltName extension or the Subject
332 commonName field.
- 333 **Subordinate CA:** A Certification Authority whose Certificate is signed by the Root CA, or another
334 Subordinate CA.
- 335 **Subscriber:** A natural person or Legal Entity to whom a Certificate is issued and who is legally bound by
336 a Subscriber Agreement or Terms of Use.
- 337 **Subscriber Agreement:** An agreement between the CA and the Applicant/Subscriber that specifies the
338 rights and responsibilities of the parties.
- 339 **Subsidiary Company:** A company that is controlled by a Parent Company.
- 340 **Technically Constrained Subordinate CA Certificate:** A Subordinate CA certificate which uses a
341 combination of Extended Key Usage settings and Name Constraint settings to limit the scope within
342 which the Subordinate CA Certificate may issue Subscriber or additional Subordinate CA Certificates.
- 343 **Terms of Use:** Provisions regarding the safekeeping and acceptable uses of a Certificate issued in
344 accordance with these Requirements when the Applicant/Subscriber is an Affiliate of the CA or is the
345 CA.
- 346 **Test Certificate:** A Certificate with a maximum validity period of 30 days and which: (i) includes a
347 critical extension with the specified Test Certificate CABF OID, or (ii) is issued under a CA where there
348 are no certificate paths/chains to a root certificate subject to these Requirements.
- 349 **Trustworthy System:** Computer hardware, software, and procedures that are: reasonably secure from
350 intrusion and misuse; provide a reasonable level of availability, reliability, and correct operation; are
351 reasonably suited to performing their intended functions; and enforce the applicable security policy.
- 352 **Unregistered Domain Name:** A Domain Name that is not a Registered Domain Name.

- 353 **Valid Certificate:** A Certificate that passes the validation procedure specified in RFC 5280.
- 354 **Validation Specialists:** Someone who performs the information verification duties specified by these
355 Requirements.
- 356 **Validity Period:** The period of time measured from the date when the Certificate is issued until the
357 Expiry Date.
- 358 **Wildcard Certificate:** A Certificate containing an asterisk (*) in the left-most position of any of the
359 Subject Fully-Qualified Domain Names contained in the Certificate.
- 360 **Zone:** A subset of Certificate Systems created by the logical or physical partitioning of systems from
361 other Certificate Systems.

362 1.6.2 Acronyms

Acronym	Meaning
AICPA	American Institute of Certified Public Accountants
CA	Certification Authority
CAA	Certification Authority Authorization
ccTLD	Country Code Top-Level Domain
CICA	Canadian Institute of Chartered Accountants
CP	Certificate Policy
CPS	Certification Practice Statement
CRL	Certificate Revocation List
DBA	Doing Business As
DNS	Domain Name System
FIPS	(US Government) Federal Information Processing Standard
FQDN	Fully Qualified Domain Name
IM	Instant Messaging
IANA	Internet Assigned Numbers Authority
ICANN	Internet Corporation for Assigned Names and Numbers
ISO	International Organization for Standardization
NIST	(US Government) National Institute of Standards and Technology
OCSP	Online Certificate Status Protocol
OID	Object Identifier
PKI	Public Key Infrastructure
RA	Registration Authority
S/MIME	Secure MIME (purpose Internet Mail Extensions)
SSL	Secure Sockets Layer
TLD	Top-Level Domain
TLS	Transport Layer Security

Acronym	Meaning
VOIP	Voice Over Internet Protocol

1.6.3 References

- ETSI EN 319 403, Electronic Signatures and Infrastructures (ESI); Trust Service Provider Conformity Assessment - Requirements for conformity assessment bodies assessing Trust Service Providers
- ETSI EN 319 411-1, Electronic Signatures and Infrastructures (ESI); Policy and security requirements for Trust Service Providers issuing certificates; Part 1: General requirements
- ETSI TS 102 042, Electronic Signatures and Infrastructures (ESI); Policy requirements for certification authorities issuing public key certificates.
- FIPS 140-2, Federal Information Processing Standards Publication - Security Requirements For Cryptographic Modules, Information Technology Laboratory, National Institute of Standards and Technology, May 25, 2001.
- ISO 21188:2006, Public key infrastructure for financial services – Practices and policy framework.
- NIST SP 800-89, Recommendation for Obtaining Assurances for Digital Signature Applications, http://csrc.nist.gov/publications/nistpubs/800-89/SP-800-89_November2006.pdf.
- RFC2119, Request for Comments: 2119, Key words for use in RFCs to Indicate Requirement Levels, Bradner, March 1997.
- RFC2527, Request for Comments: 2527, Internet X.509 Public Key Infrastructure: Certificate Policy and Certification Practices Framework, Chokhani, et al, March 1999.
- RFC6960, Request for Comments: 6960, X.509 Internet Public Key Infrastructure Online Certificate Status Protocol - OCSP. Santesson, Myers, Ankney, Malpani, Galperin, Adams, June 2013.
- RFC3647, Request for Comments: 3647, Internet X.509 Public Key Infrastructure: Certificate Policy and Certification Practices Framework, Chokhani, et al, November 2003.
- RFC4366, Request for Comments: 4366, Transport Layer Security (TLS) Extensions, Blake-Wilson, et al, April 2006.
- RFC5019, Request for Comments: 5019, The Lightweight Online Certificate Status Protocol (OCSP) Profile for High-Volume Environments, A. Deacon, et al, September 2007.
- RFC5280, Request for Comments: 5280, Internet X.509 Public Key Infrastructure: Certificate and Certificate Revocation List (CRL) Profile, Cooper et al, May 2008.
- WebTrust for Certification Authorities, SSL Baseline with Network Security, Version 2.0, available at <http://www.webtrust.org/homepage-documents/item79806.pdf>.

392 X.509, Recommendation ITU-T X.509 (10/2012) | ISO/IEC 9594-8:2014 (E), Information technology –
393 Open Systems Interconnection – The Directory: Public-key and attribute certificate frameworks.

394 **1.6.4 Conventions**

395 The key words “MUST”, “MUST NOT”, “REQUIRED”, “SHALL”, “SHALL NOT”, “SHOULD”,
396 “SHOULD NOT”, “RECOMMENDED”, “MAY”, and “OPTIONAL” in these Requirements shall be
397 interpreted in accordance with RFC 2119.

2. PUBLICATION AND REPOSITORY RESPONSIBILITIES

The Federal PKI Policy Authority will review and update this Certificate Policy at least every 365 days to ensure compliance with CA/Browser Forum Baseline requirements. After review and approval, the CP document version number and a dated changelog entry shall be added even if no changes were deemed necessary.

The review and update shall include any changes needed to address:

- US Federal Government mission needs and changes to procedures to support the missions
- CA/Browser Forum Baseline Requirements updates

If changes to CA/Browser Forum Baseline requirements are made and have applicable requirements which require compliance earlier than 365 days from the last update, the Federal PKI Policy Authority will update the policy to meet those compliance timeframes and ensure all CA's and associated CA Certification Practice Statements are updated.

Each CA SHALL develop, implement, enforce, and update at least every 365 days a Certification Practice Statement (CPS) that describes in detail how the CA implements the requirements of this CP.

An annual self-assessment shall be conducted by any CA operating under this Certificate Policy and the accompanying CA CPS to show compliance with the latest version of this certificate policy and the CA/Browser Forum Baseline Requirements. The CA shall indicate the self-assessment by incrementing the CPS version number and adding a dated changelog entry to the change record.

2.1 Repositories

The CA SHALL make revocation information for Subordinate Certificates and Subscriber Certificates available in accordance with this Policy.

The CA shall post all CA certificates and CRLs issued by the CA in a repository that is publicly accessible through all Uniform Resource Identifier (URI) references asserted in valid certificates issued by that CA. The CA SHALL document the Uniform Resource Identifiers for CA certificates and CRLs in the CPS.

2.2 Publication of information

The Federal PKI Policy Authority SHALL publicly post this Certificate Policy on <INSERT URL>, ensuring it is readily accessible on a 24x7 basis.

All CAs SHALL publicly disclose redacted Certification Practice Statement through a readily accessible online means that is available on a 24x7 basis. The CA SHALL publicly disclose its CA practices and audits to the extent required by the CA's audit scheme (see Section 8.1). The disclosures SHALL include all the material required by RFC 3647, and SHALL be structured in accordance with or RFC 3647. The Certification Practice Statement SHALL state the CA's practice on processing CAA Records for Fully

432 Qualified Domain Names. The CA SHALL log all actions taken, if any, consistent with its processing
433 practice.

434 The Federal PKI Policy Authority and/or a designee and/or the CAs SHALL publish test Web pages that
435 allow Application Software Suppliers to test their software with Subscriber Certificates from the Issuing
436 CAs that chain up to the publicly trusted Root Certificate. At a minimum, separate Web pages SHALL be
437 published showing Subscriber Certificates that are (i) valid, (ii) revoked, and (iii) expired.

438 **2.3 Time or frequency of publication**

439 The Federal PKI Policy Authority and CAs shall update and publish the Certificate Policy and
440 Certification Practices Statements in accordance with Section 2.0.

441 All CAs approved to issue a CA certificate SHALL post to the Repository any issued CA certificate as
442 soon as possible after issuance but no later than 15 days after issuance. The Federal PKI Policy Authority
443 or designee shall disclose the CA certificate and submit the CA certificate to trust stores and applicable
444 databases, such as the Common CA Database, within thirty (30) days of issuance.

445 Each CA SHALL publish CRLs in accordance with Section 4.9.7.

446 **2.4 Access controls on repositories**

447 Each CA shall make its Repository publicly available in a read-only manner.

3. IDENTIFICATION AND AUTHENTICATION

3.1 Naming

3.1.1 Types of names

This policy restricts the subject names of CAs. CAs that issue certificates under this policy SHALL have distinguished names using geo-political names consisting of country, organization, and common name. Organization units may only be used with approval by the Policy Authority.

Subscriber certificates issued under this policy SHALL use distinguished names and subject alternative names that comply with Section 7.1.4, and the certificate profiles.

3.1.2 Need for names to be meaningful

No stipulation.

3.1.3 Anonymity or pseudonymity of subscribers

Subscribers are not identified in Domain Validation certificates. Only the country (US) and domain name is included in the subject information.

Subscribers are partially identified in Organizational Validation certificates. The organization and location of the U.S. Government are included in the subject information. All Organizational Validation certificates only include an organization of U.S. Government and no additional organizational unit information.

Relying parties should consider certificates to be issued by the U.S. Government for U.S. Government assets and all Subscribers to be affiliated with the U.S. Government.

3.1.4 Rules for interpreting various name forms

Distinguished names in certificates are interpreted using the X.500 Standard and the ASN.1 syntax.

The subject name in CA certificates SHALL match the issuer name in certificates issued by the subject, as required by RFC 5280.

3.1.5 Uniqueness of names

The common name attribute for Root CA(s) SHALL be unique. The common name attribute for Subordinate CAs SHALL be unique from all other Subordinate CAs.

3.1.6 Recognition, authentication, and role of trademarks

CAs operating under this policy shall not issue a certificate that knowingly infringes any trademark.

The Policy Authority shall resolve disputes involving names and trademarks.

3.2 Initial identity validation

3.2.1 Method to prove possession of private key

Issuing CA's SHALL describe the method(s) used to prove possession of private keys in the Certification Practice Statement(s).

Example: The CA verifies the digital signature on a signed object. The signed object is a PKCS#10 certification signing request.

3.2.2 Authentication of Organization and Domain Identity

All Domain Validation certificates issued under this Certificate Policy MAY include Subject Identity Information of countryName and SHALL NOT include any other Subject Identity Information with the exception of the required Common Name. If the Applicant requests a Domain Validation Certificate that will contain Subject Identity Information to include the the countryName field, then the CA SHALL verify the country associated with the Subject using a verification process meeting the requirements of Section 3.2.2.3.

All Organization Validation certificates issued under this Certificate Policy SHALL include Subject Identity Information of countryName **and** Organization **and** State and SHALL NOT include any other Subject Identity Information with the exception of the required Common Name. If the Applicant requests a Certificate that will contain Subject Identity Information comprised of the countryName field and Organization and State, then the CA SHALL verify the identity of the Applicant, and the authenticity of the Applicant Representative's certificate request using a verification process meeting the requirements Section 3.2.2.1.

Issuing CA's SHALL describe these verification processes in the Certification Practice Statement(s).

The CA SHALL inspect any document relied upon under this Section for alteration or falsification.

3.2.2.1 Identity

Any Organization Validation certificates issued under this Certificate Policy are for U.S. Government mission purposes and for consumers, partners, and other relying parties to identify the U.S. as the subject. All Organization Validation certificates SHALL include Subject Identity Information of countryName **and** Organization **and** State and SHALL NOT include any other Subject Identity Information with the exception of the required Common Name. See Section 7.1.4.2.2.

If the Subject Identity Information is to include the name of our organization (o=U.S. Government), the CA SHALL verify the identity and address of the organization and that the address is the Applicant's address of existence or operation. Asserting U.S. Government as the organization SHALL be verified by the CA using documentation provided by, or through communication with, at least one of the following:

1. A government agency in the jurisdiction of the Applicant's legal creation, existence, or recognition;
2. A third party database that is periodically updated and considered a Reliable Data Source such as the DotGov and DotMil Domain Name Registrars;
3. <not allowed>
4. An Attestation Letter.

The CA MAY use the same documentation or communication described in 1 through 4 above to verify both the Applicant's identity and address.

Practice Note: U.S. Government entities are in the jurisdiction of the U.S. Government. Verification of the domain to be part of the U.S. Government as the top level organization (o=U.S. Government) SHOULD suffice to assert the U.S. Government primary headquarter locations for address. This Certificate Policy relies upon the establishment of three branches of the U.S. Government as defined in the U.S. Constitution. All three branches of the U.S. Government have primary headquarters located in the city of Washington in the District of Columbia in the United States of America. *End Practice Note*

3.2.2.2 DBA/Tradename

Subject Identity Information SHALL NOT include a DBA or tradename.

3.2.2.3 Verification of Country

This Certificate Policy is restricted to the gTLDs for DotGov and DotMil, registered as the sub-category of *sponsored* TLDs (sTLDs) with ICANN.

DotGov is sponsored by the U.S. Government's General Services Administration. DotGov regulations are defined in 41 CFR Part 102-173. Under 41 CFR Part 102-173.30, registration in the DotGov domain is only available to official governmental organizations in the United States including Federal, State and local governments, and Native Sovereign Nations.

DotMil is sponsored by the U.S. Government's Department of Defense. The DotMil domain exists for the exclusive use of the Department of Defense and is referenced in Department of Defense Issuances Informational (DoDI) 8410.

The Domain Name Registrars for both DotGov and DotMil are managed by the U.S. Government.

This Certificate Policy asserts for all Certificate Authorities operating under this policy that the inclusion of subject:countryName in any Subscriber certificate is verified by:

- Section 3.2.2.3 of the CA/B Forum Baseline Requirements, option (c): information provided by the Domain Name Registrar
- Section 3.2.2.3 of the CA/B Forum Baseline Requirements, option (b): the ccTLD of the requested Domain Name. This CP asserts comparable controls for the sTLDs operated by the U.S. Government.

Issuing CA's SHALL describe these verification processes in the Certification Practice Statement(s).

3.2.2.4 Validation of Domain Authorization or Control

546 This section defines the permitted processes and procedures for validating the Applicant's ownership or
547 control of the domain.

548 This Certificate Policy allows for procedures adhering to:

- 549 • 3.2.2.4.5 Domain Authorization Document
- 550 • 3.2.2.4.6 Agreed-Upon Change to Website
- 551 • 3.2.2.4.10 TLS Using a Random Number

552 Wildcard certificates are not allowed to be validated using 3.2.2.4.6 or 3.2.2.4.10. All wildcard
553 certificates SHALL require a Domain Authorization Document signed by the Domain Contact authorizing
554 the issuing of a wildcard certificate.

555 The CA SHALL confirm that, as of the date the Certificate issues, the CA has validated each Fully-
556 Qualified Domain Name (FQDN) listed in the Certificate using at least one of the methods listed in
557 Section 3.2.2.4.x.

558 Completed confirmations of Applicant authority may be valid for the issuance of multiple certificates
559 over time. In all cases, the confirmation must have been initiated within the time period specified in the
560 relevant requirement (Section 3.3.1 of this document) prior to certificate issuance. For purposes of
561 domain validation, the term Applicant includes the Applicant's U.S. Government Department, Agency,
562 Commission, component, or other organizational unit defined in United States Code.

563 Note: FQDNs may be listed in Subscriber Certificates using dNSNames in the subjectAltName extension
564 or in Subordinate CA Certificates via dNSNames in permittedSubtrees within the Name Constraints
565 extension.

566 **3.2.2.4.1 [Reserved]**

567 Not allowed as of the Effective Date of this Certificate Policy.

568 **3.2.2.4.2 [Reserved]**

569 Not allowed as of the Effective Date of this Certificate Policy.

570 **3.2.2.4.3 [Reserved]**

571 Not allowed as of the Effective Date of this Certificate Policy.

572 **3.2.2.4.4 [Reserved]**

573 Not allowed as of the Effective Date of this Certificate Policy.

574 **3.2.2.4.5 Domain Authorization Document**

575 Confirming the Applicant's control over the requested FQDN by relying upon the attestation to the
576 authority of the Applicant to request a Certificate contained in a Domain Authorization Document. The
577 Domain Authorization Document SHALL substantiate that the communication came from the Domain
578 Contact. The CA SHALL verify that the Domain Authorization Document was either (i) dated on or after

the date of the domain validation request or (ii) that the WHOIS data has not materially changed since a previously provided Domain Authorization Document for the Domain Name Space.

3.2.2.4.6 Agreed-Upon Change to Website

Confirming the Applicant's control over the requested FQDN by confirming one of the following under the "/.well-known/pki-validation" directory, or another path registered with IANA for the purpose of Domain Validation, on the Authorization Domain Name that is accessible by the CA via HTTP/HTTPS over an Authorized Port:

1. The presence of Required Website Content contained in the content of a file or on a web page in the form of a meta tag. The entire Required Website Content MUST NOT appear in the request used to retrieve the file or web page, or
2. The presence of the Request Token or Request Value contained in the content of a file or on a webpage in the form of a meta tag where the Request Token or Random Value MUST NOT appear in the request.

If a Random Value is used, the CA SHALL provide a Random Value unique to the certificate request and SHALL not use the Random Value after 30 days.

Note: Examples of Request Tokens include, but are not limited to: (i) a hash of the public key; (ii) a hash of the Subject Public Key Info [X.509]; and (iii) a hash of a PKCS#10 CSR. A Request Token may also be concatenated with a timestamp or other data.

The CA SHALL define in its CPS the format of Request Tokens it accepts and SHALL document the "/.well-known/pki-validation/" directory and any other paths registered with IANA.

3.2.2.4.7 [Reserved]

3.2.2.4.8 [Reserved]

3.2.2.4.9 [Reserved]

3.2.2.4.10. TLS Using a Random Number

Confirming the Applicants control over the requested FQDN by confirming the presence of a Random Value within a Certificate on the Authorization Domain Name which is accessible by the CA via TLS over an Authorized Port.

3.2.2.5 Authentication for an IP Address

Not allowed as of the Effective Date of this Certificate Policy. IP Addresses are not allowed in the certificate profiles under this Certificate Policy.

3.2.2.6 Wildcard Domain Validation

Before issuing a certificate with a wildcard character (*) in a CN or subjectAltName, the CA SHALL establish and follow a documented procedure and technical controls that determines if the wildcard character occurs in the first label position to the left of the DotGov and DotMil suffixes (e.g. *.gov, *.mil). If a wildcard would fall within the label immediately to the left of the DotGov and DotMil suffixes

614 (e.g. *.gov, *.mil), CAs SHALL refuse issuance. All CAs are prohibited from issuing any Wildcard
615 Certificate to the entire gTLDs for DotGov and / or DotMil.

616 Wildcard certificates are not allowed to be validated using 3.2.2.4.6 or 3.2.2.4.10. All wildcard
617 certificates SHALL require a Domain Authorization Document (3.2.2.4.5) by the Domain Contact
618 authorizing the issuing of a certificate that includes a wildcard domain.

619 3.2.2.7 Data Source Accuracy

620 Prior to using any data source as a Reliable Data Source, the CA SHALL evaluate the source for its
621 reliability, accuracy, and resistance to alteration or falsification. The CA SHOULD consider the following
622 during its evaluation:

- 623 1. The age of the information provided,
- 624 2. The frequency of updates to the information source,
- 625 3. The data provider and purpose of the data collection,
- 626 4. The public accessibility of the data availability, and
- 627 5. The relative difficulty in falsifying or altering the data.

628 Databases maintained by the CA or affiliated government agencies do not qualify as a Reliable Data
629 Source if the primary purpose of the database is to collect information for the purpose of fulfilling the
630 validation requirements under this Section 3.2.

631 3.2.2.8 CAA Records

632 When processing CAA records, CAs SHALL process the issue, issuewild, and iodef property tags as
633 specified in RFC 6844, although they are not required to act on the contents of the iodef property tag.
634 Additional property tags MAY be supported, but SHALL NOT conflict with or supersede the mandatory
635 property tags set out in this document. CAs SHALL respect the critical flag and not issue a certificate if
636 they encounter an unrecognized property with this flag set.

637 RFC 6844 requires that CAs “MUST NOT issue a certificate unless either (1) the certificate request is
638 consistent with the applicable CAA Resource Record set or (2) an exception specified in the relevant
639 Certification Practices Statement applies.”

640 For issuances conforming to this Certificate Policy, CAs SHALL NOT rely on any exceptions specified
641 in their respective CPS unless they are one of the following:

- 642 • CAA checking is optional for certificates for which a Certificate Transparency pre-certificate was
643 created and logged in at least two public logs, and for which CAA was checked.
- 644 • CAA checking is optional if the CA or an Affiliate of the CA is the DNS Operator (as defined in
645 RFC 7719) of the domain’s DNS.

646 CAs are permitted to treat a record lookup failure as permission to issue if:

- 647 • the failure is outside the CA’s infrastructure;
- 648 • the lookup has been retried at least once; and
- 649 • the domain’s zone does not have a DNSSEC validation chain to the ICANN root.

650 CAs SHALL document potential issuances that were prevented by a CAA record in sufficient detail to
651 provide feedback on the circumstances, and SHOULD dispatch reports of such issuance requests to the
652 contact(s) stipulated in the CAA iodef record(s), if present. CAs are not expected to support URL
653 schemes in the iodef record other than mailto: or https:.

654 **3.2.3 Authentication of individual identity**

655 Subscriber certificates identifying and authenticating natural born persons or individual identity SHALL
656 NOT be issued under this policy.

657 **3.2.4 Non-verified subscriber information**

658 Non-verified subscriber information SHALL NOT be asserted in any certificates under this Certificate
659 Policy.

660 **3.2.5 Validation of authority**

661 If the Applicant for a Certificate containing Subject Identity Information is an organization, the CA
662 SHALL use a Reliable Method of Communication to verify the authenticity of the Applicant
663 Representative's certificate request.

664 The CA MAY use the sources listed in section 3.2.2.1 to verify the Reliable Method of Communication.
665 Provided that the CA uses a Reliable Method of Communication, the CA MAY establish the authenticity
666 of the certificate request directly with the Applicant Representative or with an authoritative source within
667 the Applicant's organization, such as the Applicant's main business offices, human resource offices,
668 information technology offices, or other division that the CA deems appropriate.

669 In addition, the CA SHALL establish a process that allows an Applicant to specify the individuals who
670 may request Certificates. If an Applicant specifies, in writing, the individuals who may request a
671 Certificate, then the CA SHALL NOT accept any certificate requests that are outside this specification.
672 The CA SHALL provide an Applicant with a list of its authorized certificate requesters upon the
673 Applicant's verified written request.

674 **3.2.6 Criteria for Interoperation or Certification**

675 CAs SHALL NOT have Cross Certificate(s) that identify the CA as the Subject without explicit written
676 permission of the Policy Authority. Any Cross Certificates SHALL be disclosed publicly, submitted to
677 one or more Certificate Transparency Logs, published to the Repository, and identified in the update to
678 the CPS.

679 **3.3 Identification and authentication for re-key requests**

680 Re-key requests are not allowed under this policy. All requests are treated as new certificate requests.

681 **3.3.1 Identification and authentication for routine re-key**

682 See Section 3.3

683 **3.3.2 Identification and authentication for re-key after revocation**

684 See Section 3.3

685 **3.4 Identification and authentication for revocation request**

686 No stipulation.

4. CERTIFICATE LIFE-CYCLE OPERATIONAL REQUIREMENTS

4.1 Certificate Application

4.1.1 Who can submit a certificate application

In accordance with Section 5.5.2, all CAs SHALL maintain an internal database of all previously revoked Certificates and previously rejected certificate requests due to suspected phishing or other fraudulent usage or concerns. All CA SHALL use this information to identify subsequent suspicious certificate requests.

For the Root and Subordinate CAs:

- An application for a CA certificate shall be submitted by an authorized representative of the applicant CA.

For end entity certificates:

- A certificate application shall be submitted to the CA by the Subscriber, an Applicant Representative, or an RA on behalf of the Subscriber.

4.1.2 Enrollment process and responsibilities

For the Root and Subordinate CAs:

- The Policy Authority is responsible for approving or denying requests for CA certificate issuances.

For all CAs, prior to the issuance of any Certificate, the CA SHALL obtain the following documentation from the Applicant:

1. A certificate request, which may be electronic; and
2. An executed Subscriber Agreement or Terms of Use, which may be electronic.

The certificate request SHALL contain a request from, or on behalf of, the Applicant for the issuance of a Certificate, and a certification by, or on behalf of, the Applicant that all of the information contained therein is correct.

The CA SHALL be responsible for validating the information in the certificate request and the identity evidence to ensure the information is:

- properly formed
- accurate

- meets the requirements for the type of certificate requested: a device Domain Validation SSL end entity certificate, a device Organizational Validation SSL end entity certificate, a CA Certificate, or a Certificate Status Server (OCSP) signing certificate

All communications supporting the certificate application and issuance process SHALL be authenticated and protected from modification; any electronic transmission of shared secrets shall be protected. Communications may be electronic or out-of-band. Where electronic communications are used, cryptographic mechanisms commensurate with the strength of the public/private key pair SHALL be used. Out-of-band communications SHALL protect the confidentiality and integrity of the data.

All CAs SHALL specify the procedures for validating information and identity evidence in the CA CPS.

4.2 Certificate application processing

4.2.1 Performing identification and authentication functions

All CAs SHALL establish and follow a documented procedure for verifying all data requested for inclusion in the Certificate by the Applicant.

For end entity Domain Validation SSL certificates and end entity Organizational Validation SSL certificates:

- The Applicant information SHALL include at least one Fully-Qualified Domain Name to be included in the Certificate's SubjectAltName extension
- All Fully-Qualified Domain Names to be included in the Certificate's SubjectAltName extension SHALL be verified in accordance with Section 3.2 before issuance of the certificate
- CAA records for DotGov and DotMil domains SHALL be checked prior to issuance of any certificate and the CA SHALL act in accordance to the rules in the CAA records if present. The CA SHALL identify in Section 4.2 of the CPS the Issuer Domain Name(s) used for CAA records.

The CA MAY use the documents and data provided in Section 3.2 to verify certificate information, provided that the CA obtained the data or document from a source specified under Section 3.2 no more than 825 days prior to issuing the Certificate.

All Subordinate CAs SHALL develop, maintain, and implement documented procedures that identify and require additional verification activity for High Risk Certificate Requests for .GOV (DotGov) and .MIL (DotMil) assets prior to the Certificate's approval.

Delegated Third Parties are not allowed under this policy.

4.2.2 Approval or rejection of certificate applications

This Certificate Policy is restricted to be applicable to, and technically constrained, for DotMil and DotGov assets.

CAs SHALL reject all certificate applications containing any FQDNs that are not under the gTLDs for DotGov and DotMil.

Approval of certificate applications requires successful completion of validation per Section 3.2.

In accordance with Section 5.5.2, all CAs SHALL maintain an internal database of all previously revoked Certificates and previously rejected certificate requests due to suspected phishing or other fraudulent usage or concerns. All CAs SHALL use this information to identify subsequent suspicious certificate requests and MAY use it as the basis for rejecting a certificate request.

4.2.3 Time to process certificate applications

No stipulation.

4.3 Certificate issuance

4.3.1 CA actions during certificate issuance

Certificate issuance by the Root CA SHALL require an individual authorized by the CA (i.e. the CA system operator, system officer, or PKI administrator) to deliberately issue a direct command in order for the Root CA to perform a certificate signing operation. Issuance of a CA certificate by the Root CA SHALL require written authorization by the Policy Authority.

All end entity certificates for Domain Validation SSL and Organizational Validation SSL SHALL assert a Certificate Transparency (CT) Signed Certificate Timestamp (SCT) via the x509v3 certificate extension.

The Issuing CA SHALL submit a precertificate to a minimum of TWO Certificate Transparency Logs for certificates with a validity period less than or equal to 395 days. The Issuing CA SHALL submit a precertificate to a minimum of THREE Certificate Transparency Logs for certificates with a validity period greater than 395 days and less than or equal to 825 days. There is no limit on the maximum number of CT Logs which may be submitted to.

- At least one of the Certificate Transparency Logs SHALL be a CT Log operated by Google.
- At least one of the Certificate Transparency Logs SHALL be a CT Log NOT operated by Google.

The Issuing CA SHALL include at least the same number and variety of SCTs in the x509v3 certificate extension for the end entity certificate issued.

Information included in the end entity certificates SHALL NOT be redacted prior to submission to the Certificate Transparency Logs.

4.3.2 Notification to subscriber by the CA of issuance of certificate

The CA SHALL issue the certificate according to the certificate requesting protocol used by the device (this may be automated) and, if the protocol does not provide inherent notification, also notify the authorized representative of the issuance.

4.4 Certificate acceptance

4.4.1 Conduct constituting certificate acceptance

783 Failure of the subscriber to object to the certificate or its contents shall constitute acceptance of the
784 certificate.

785 **4.4.2 Publication of the certificate by the CA**

786 As specified in Section 2.1, all CA certificates SHALL be published in repositories. All CA certificates
787 SHALL be published to the repositories within 24 hours of issuance. CAs SHALL log all end entity
788 certificates in a minimum of two (2) Certificate Transparency Log servers as outlined in Section 4.3.1.

789 **4.4.3 Notification of certificate issuance by the CA to other entities**

790 See Section 4.4.2.

791 **4.5 Key pair and certificate usage**

792 **4.5.1 Subscriber private key and certificate usage**

793 See Section 9.6.3, provisions 2. and 4.

794 The intended scope of usage for a private key shall be in accordance with the certificate profiles included
795 with this Certificate Policy.

796 **4.5.2 Relying party public key and certificate usage**

797 All CAs operating under this policy provide revocation information in accordance with Section 4.9.7 and
798 Section 4.9.9.

799 It is recommended that relying parties process and comply with this information whenever using
800 certificates in a transaction.

801 **4.6 Certificate renewal**

802 Renewal is defined as the re-issuance of a certificate with no changes to the public key, no changes to the
803 identity information, and a new validity period for the certificate.

804 **4.6.1 Circumstance for certificate renewal**

805 CA certificates SHALL NOT be renewed. End entity Domain Validation SSL certificates and end entity
806 Organizational Validation SSL certificates SHALL NOT be renewed. Certificate renewal requests
807 SHALL be treated as new applications and information verified in accordance with Section 4.2.1

808 Online Certificate Status Protocol (OCSP) Delegated responder certificates MAY be renewed.

809 **4.6.2 Who may request renewal**

810 The Policy Authority SHALL request that CAs routinely process OCSP Delegated Responder certificate
811 renewal requests at the time the original certificate is requested by the Administrator.

812 **4.6.3 Processing certificate renewal requests**

813 The CA SHALL verify that the OCSP Delegated Responder certificate expiration date SHALL NOT
814 exceed 825 days from the date of initial certificate issuance.

815 **4.6.4 Notification of new certificate issuance to subscriber**

816 See Section 4.3.2.

817 **4.6.5 Conduct constituting acceptance of a renewal certificate**

818 See Section 4.4.1.

819 **4.6.6 Publication of the renewal certificate by the CA**

820 See Section 4.4.2.

821 **4.6.7 Notification of certificate issuance by the CA to other entities**

822 See Section 4.4.2.

823 **4.7 Certificate re-key**

824 Re-key is defined as the issuance of a certificate with a new public key, no changes to the identity
825 information, and a new validity period for the certificate.

826 **4.7.1 Circumstance for certificate re-key**

827 All Certificates under this policy SHALL NOT be re-keyed. Certificate re-key requests SHALL be treated
828 as new applications and information verified in accordance with Section 4.2.1

829 **4.7.2 Who may request certification of a new public key**

830 Not applicable.

831 **4.7.3 Processing certificate re-keying requests**

832 Not applicable.

833 **4.7.4 Notification of new certificate issuance to subscriber**

834 Not applicable.

835 **4.7.5 Conduct constituting acceptance of a re-keyed certificate**

836 Not applicable.

837 **4.7.6 Publication of the re-keyed certificate by the CA**

838 Not applicable.

839 **4.7.7 Notification of certificate issuance by the CA to other entities**

840 Not applicable.

841 **4.8 Certificate modification**

842 Modification is defined as the re-issuance of a certificate with the same public key, and changes to the
843 identity information or information in the certificate (i.e. policies, key usage) other than the validity
844 period.

845 **4.8.1 Circumstance for certificate modification**

846 End entity Domain Validation SSL certificates and end entity Organizational Validation SSL certificates
847 SHALL NOT be modified. Online Certificate Status Protocol (OCSP) Delegated responder certificates
848 SHALL NOT be modified.

849 CA certificates MAY be modified to update attributes other than the public key. A CA certificate SHALL
850 NOT be modified to add restrictions not in the original certificate unless all Subscriber certificates
851 previously issued by the CA conform to the new restrictions.

852 **4.8.2 Who may request certificate modification**

853 See Section 4.1.1.

854 **4.8.3 Processing certificate modification requests**

855 Certificate issuance by the Root CA SHALL require an individual authorized by the CA (i.e. the CA
856 system operator, system officer, or PKI administrator) to deliberately issue a direct command in order for
857 the Root CA to perform a certificate signing operation. Modification of a CA certificate by the Root CA
858 SHALL require written authorization by the Policy Authority.

859 **4.8.4 Notification of new certificate issuance to subscriber**

860 See Section 4.3.2.

861 **4.8.5 Conduct constituting acceptance of modified certificate**

862 See Section 4.4.1.

4.8.6 Publication of the modified certificate by the CA

See Section 4.4.2.

4.8.7 Notification of certificate issuance by the CA to other entities

See Section 4.4.2.

4.9 Certificate revocation and suspension

4.9.1 Circumstances for revocation

4.9.1.1 Reasons for Revoking a Subscriber Certificate

The CA SHALL revoke a Certificate as rapidly as possible but within 24 hours if one or more of the following occurs:

1. The Subscriber requests in writing that the CA revoke the Certificate;
2. The Subscriber notifies the CA that the original certificate request was not authorized and does not retroactively grant authorization;
3. The CA obtains evidence that the Subscriber's Private Key corresponding to the Public Key in the Certificate suffered a Key Compromise or no longer complies with the requirements of Sections 6.1.5 and 6.1.6;
4. The CA obtains evidence that the Certificate was misused;
5. The CA is made aware that a Subscriber has violated one or more of its material obligations under the Subscriber Agreement or Terms of Use;
6. The CA is made aware of any circumstance indicating that use of a Fully-Qualified Domain Name in the Certificate is no longer legally permitted (e.g. a court or arbitrator has revoked the right to use the Domain Name or the Domain Name Registrant has failed to renew the Domain Name under DotGov and/or DotMil gTLDs);
7. The CA is made aware that a Wildcard Certificate has been used to authenticate a fraudulently misleading subordinate Fully-Qualified Domain Name;
8. The CA is made aware of a material change in the information contained in the Certificate;
9. The CA is made aware that the Certificate was not issued in accordance with this Certificate Policy or the CA's Certification Practice Statement;
10. The CA determines that any of the information appearing in the Certificate is inaccurate or misleading;
11. The CA ceases operations for any reason and has not made arrangements for another CA to provide revocation support for the Certificate;
12. The CA's right to issue Certificates under these Requirements expires or is revoked or terminated, unless the CA has made arrangements to continue maintaining the CRL/OCSP Repository;
13. The CA is made aware of a possible compromise of the Private Key of the Subordinate CA used for issuing the Certificate;
14. Revocation is required by the CA's Certificate Policy and/or Certification Practice Statement; or
15. The technical content or format of the Certificate presents an unacceptable risk to Application Software Suppliers or Relying Parties (e.g. the FPKI Policy Authority or CA/Browser Forum might determine that a deprecated cryptographic/signature algorithm or key size presents an

903 unacceptable risk and that such Certificates should be revoked and replaced by CAs within a
904 given period of time).

905 **4.9.1.2 Reasons for Revoking a Subordinate CA Certificate**

906 The Issuing CA SHALL revoke a Subordinate CA Certificate within seven (7) days if one or more of the
907 following occurs:

- 908 1. The Subordinate CA requests revocation in writing;
- 909 2. The Subordinate CA notifies the Issuing CA that the original certificate request was not
910 authorized and does not retroactively grant authorization;
- 911 3. The Issuing CA obtains evidence that the Subordinate CA's Private Key corresponding to the
912 Public Key in the Certificate suffered a Key Compromise or no longer complies with the
913 requirements of Sections 6.1.5 and 6.1.6;
- 914 4. The Issuing CA obtains evidence that the Certificate was misused;
- 915 5. The Issuing CA is made aware that the Certificate was not issued in accordance with or that
916 Subordinate CA has not complied with this CP or the applicable Certificate Policy or
917 Certification Practice Statement;
- 918 6. The Issuing CA determines that any of the information appearing in the Certificate is inaccurate
919 or misleading;
- 920 7. The Issuing CA or Subordinate CA ceases operations for any reason and has not made
921 arrangements for another CA to provide revocation support for the Certificate;
- 922 8. The Issuing CA's or Subordinate CA's right to issue Certificates under these Requirements
923 expires or is revoked or terminated, unless the Issuing CA has made arrangements to continue
924 maintaining the CRL/OCSP Repository;
- 925 9. Revocation is required by the Issuing CA's Certificate Policy and/or Certification Practice
926 Statement; or
- 927 10. The technical content or format of the Certificate presents an unacceptable risk to Application
928 Software Suppliers or Relying Parties (e.g. the FPKI Policy Authority or CA/Browser Forum
929 might determine that a deprecated cryptographic/signature algorithm or key size presents an
930 unacceptable risk and that such Certificates should be revoked and replaced by CAs within a
931 given period of time).

932 **4.9.2 Who can request revocation**

933 The Subscriber, RA, or Issuing CA can initiate revocation. Additionally, Subscribers, Relying Parties,
934 Application Software Suppliers, and other third parties may submit Certificate Problem Reports
935 informing the issuing CA of reasonable cause to revoke the certificate.

936 The Policy Authority SHALL direct any revocation of a CA certificate.

937 **4.9.3 Procedure for revocation request**

938 The CA SHALL provide a process for Subscribers to request revocation of their own Certificates. The
939 process SHALL be described in the CA's Certificate Policy or Certification Practice Statement. The CA
940 SHALL maintain a continuous 24x7 ability to accept and respond to revocation requests and related
941 inquiries.

942 The CA SHALL provide Subscribers, Relying Parties, Application Software Suppliers, and other third
943 parties with clear instructions for reporting suspected Private Key Compromise, Certificate misuse, or
944 other types of fraud, compromise, misuse, inappropriate conduct, or any other matter related to
945 Certificates. The CA SHALL publicly disclose the instructions through a readily accessible online means.

946 A request to revoke a certificate shall identify the certificate to be revoked, explain the reason for
947 revocation, and allow the request to be authenticated (e.g., digitally or manually signed).

948 **4.9.4 Revocation request grace period**

949 There is no revocation grace period.

950 **4.9.5 Time within which CA must process the revocation request**

951 The CA SHALL begin investigation of a of a Request for Revocation or a Certificate Problem Report
952 immediately upon receipt, and decide whether revocation or other appropriate action is warranted based
953 on at least the following criteria:

- 954 1. The nature of the alleged problem;
- 955 2. The number of Certificate Problem Reports received about a particular Certificate or Subscriber;
- 956 3. The entity making the complaint (for example, a complaint from a law enforcement Office of the
957 Inspector General (OIG) official that a Web site violates Federal regulation should carry more
958 weight than a complaint from a user alleging that they were unable to complete their transaction);
959 and
- 960 4. Relevant legislation.

961 **4.9.6 Revocation checking requirement for relying parties**

962 No stipulation.

963 (Note: Following certificate issuance, a certificate may be revoked for reasons stated in Section 4.9.1.
964 Therefore, relying parties should check the revocation status of all certificates that contain a CDP or
965 OCSP pointer.)

966 **4.9.7 CRL issuance frequency**

967 For the status of Subscriber Certificates:

- 968 • All CAs SHALL publish CRLs. On-line CAs SHALL update and reissue CRLs at least once
969 every 24 hours and the value of the nextUpdate field MUST NOT be more than seven days
970 beyond the value of the thisUpdate field

971 For the status of Subordinate CA Certificates:

- 972 • The CA SHALL update and reissue CRLs at least (i) once every 31 days and (ii) within 24 hours
973 after revoking a Subordinate CA Certificate, and the value of the nextUpdate field SHALL NOT
974 be more than 32 days beyond the value of the thisUpdate field.

4.9.8 Maximum latency for CRLs

CRLs shall be published within 4 hours of generation. Furthermore, each CRL shall be published no later than the time specified in the nextUpdate field of the previously issued CRL for same scope.

4.9.9 On-line revocation/status checking availability

OCSP responses SHALL conform to RFC6960 and/or RFC5019. OCSP responses SHALL either:

1. Be signed by the CA that issued the Certificates whose revocation status is being checked, or
2. Be signed by an OCSP Responder whose Certificate is signed by the CA that issued the Certificate whose revocation status is being checked.

In the latter case, the OCSP signing Certificate MUST contain an extension of type id-pkix-ocsp-nocheck, as defined by RFC6960.

4.9.10 On-line revocation checking requirements

The CA SHALL support an OCSP capability using the GET method for Certificates issued in accordance with these Requirements.

For the status of Subscriber Certificates:

- The OCSP Responder SHALL update the information used to respond to requests within 4 hours of a new CRL being issued by the CA for all requests. OCSP responses from this service SHALL have a maximum expiration time of ten (10) days

For the status of Subordinate CA Certificates:

- The CA SHALL update information provided via an Online Certificate Status Protocol at least (i) every 31 days and (ii) within 24 hours after revoking a Subordinate CA Certificate.

If the OCSP responder receives a request for status of a certificate that has not been issued, then the responder SHALL NOT respond with a “good” status. The CA SHALL monitor the responder for such requests as part of its security response procedures.

OCSP responders for CAs which are not Technically Constrained in line with Section 7.1.5 MUST NOT respond with a “good” status for such certificates.

4.9.11 Other forms of revocation advertisements available

If the Subscriber Certificate is for a high-traffic FQDN, the CA MAY rely on stapling, in accordance with [RFC4366], to distribute its OCSP responses. In this case, the CA SHALL ensure that the Subscriber “staples” the OCSP response for the Certificate in its TLS handshake. The CA SHALL enforce this requirement on the Subscriber either contractually, through the Subscriber Agreement or Terms of Use, or by technical review measures implemented by the CA.

4.9.12 Special requirements re key compromise

1007 See Section 4.9.1. When a CA certificate is revoked a CRL SHALL be issued within 24 hours of
1008 notification.

1009 **4.9.13 Circumstances for suspension**

1010 Certificates issued under this policy SHALL NOT be suspended.

1011 **4.9.14 Who can request suspension**

1012 Not applicable.

1013 **4.9.15 Procedure for suspension request**

1014 Not applicable.

1015 **4.9.16 Limits on suspension period**

1016 Not applicable.

1017 **4.10 Certificate status services**

1018 **4.10.1 Operational characteristics**

1019 Revocation entries on a CRL or OCSP Response SHALL NOT be removed until after the Expiry Date of
1020 the revoked Certificate.

1021 **4.10.2 Service availability**

1022 The CA SHALL operate and maintain its CRL and OCSP capability with resources sufficient to provide a
1023 response time of ten seconds or less under normal operating conditions.

1024 The CA SHALL maintain an online 24x7 Repository that application software can use to automatically
1025 check the current status of all unexpired Certificates issued by the CA.

1026 The CA SHALL maintain a continuous 24x7 ability to respond internally to a high-priority Certificate
1027 Problem Report, and where appropriate, forward such a complaint to law enforcement authorities, and/or
1028 revoke a Certificate that is the subject of such a complaint.

1029 **4.10.3 Optional features**

1030 No stipulation.

1031 **4.11 End of subscription**

1032 No stipulation.

1033 **4.12 Key escrow and recovery**

1034 **4.12.1 Key escrow and recovery policy and practices**

1035 Private keys for certificates issued under this policy SHALL NOT be escrowed.

1036 **4.12.2 Session key encapsulation and recovery policy and practices**

1037 Not applicable.

5. MANAGEMENT, OPERATIONAL, AND PHYSICAL CONTROLS

The CA SHALL develop, implement, and maintain a comprehensive security program designed to:

1. Protect the confidentiality, integrity, and availability of Certificate Data and Certificate Management Processes;
2. Protect against anticipated threats or hazards to the confidentiality, integrity, and availability of the Certificate Data and Certificate Management Processes;
3. Protect against unauthorized or unlawful access, use, disclosure, alteration, or destruction of any Certificate Data or Certificate Management Processes;
4. Protect against accidental loss or destruction of, or damage to, any Certificate Data or Certificate Management Processes; and
5. Comply with all other security requirements applicable to the CA by law.

The Certificate Management Process SHALL include:

1. physical security and environmental controls;
2. system integrity controls, including configuration management, integrity maintenance of trusted code, and malware detection/prevention;
3. network security and firewall management, including port restrictions and IP address filtering;
4. user management, separate trusted-role assignments, education, awareness, and training; and
5. logical access controls, activity logging, and inactivity time-outs to provide individual accountability.

The CA's security program SHALL include an annual Risk Assessment that:

1. Identifies foreseeable internal and external threats that could result in unauthorized access, disclosure, misuse, alteration, or destruction of any Certificate Data or Certificate Management Processes;
2. Assesses the likelihood and potential damage of these threats, taking into consideration the sensitivity of the Certificate Data and Certificate Management Processes; and
3. Assesses the sufficiency of the policies, procedures, information systems, technology, and other arrangements that the CA has in place to counter such threats.

Based on the Risk Assessment, the CA SHALL develop, implement, and maintain a security plan consisting of security procedures, measures, and products designed to achieve the objectives set forth above and to manage and control the risks identified during the Risk Assessment, commensurate with the sensitivity of the Certificate Data and Certificate Management Processes. The security plan SHALL include administrative, organizational, technical, and physical safeguards appropriate to the sensitivity of the Certificate Data and Certificate Management Processes. The security plan SHALL also take into account then-available technology and the cost of implementing the specific measures, and SHALL implement a reasonable level of security appropriate to the harm that might result from a breach of security and the nature of the data to be protected.

5.1 PHYSICAL SECURITY CONTROLS

1076 CA equipment SHALL be protected from unauthorized access while the cryptographic module is installed
1077 and activated. The CA SHALL implement physical access controls to reduce the risk of equipment
1078 tampering even when the cryptographic module is not installed and activated. CA cryptographic tokens
1079 SHALL be protected against theft, loss, and unauthorized use.

1080 All the physical control requirements specified below apply equally to the Root CA and Subordinate CAs,
1081 and any remote workstations used to administer the CAs, except where specifically noted.

1082 **5.1.1 Site location and construction**

1083 The location and construction of the facility housing the CA equipment, as well as sites housing remote
1084 workstations used to administer the CAs, SHALL be consistent with facilities used to house high-value,
1085 sensitive information. The site location and construction, when combined with other physical security
1086 protection mechanisms such as guards, high security locks, and intrusion sensors, SHALL provide robust
1087 protection against unauthorized access to the CA equipment and records.

1088 **5.1.2 Physical access**

1089 At a minimum, the physical access controls for CA equipment and Certificate Status Authority (CSA)
1090 equipment, as well as remote workstations used to administer the CAs, SHALL:

- 1091 • Ensure that no unauthorized access to the hardware is permitted.
- 1092 • Ensure that all removable media and paper containing sensitive plain-text information is stored in
1093 secure containers.
- 1094 • Be manually or electronically monitored for unauthorized intrusion at all times.
- 1095 • Ensure an access log is maintained and inspected periodically.
- 1096 • Require two-person physical access control to both the cryptographic module and computer
1097 systems.

1098 When not in use, removable cryptographic modules, activation information used to access or enable
1099 cryptographic modules, and CA equipment SHALL be placed in secure containers. Activation data
1100 SHALL be either memorized or recorded and stored in a manner commensurate with the security afforded
1101 the cryptographic module, and SHALL not be stored with the cryptographic module or removable
1102 hardware associated with remote workstations used to administer the CA.

1103 A security check of the facility housing the CA equipment or remote workstations used to administer the
1104 CAs SHALL occur if the facility is to be left unattended. At a minimum, the check SHALL verify the
1105 following:

- 1106 • The equipment is in a state appropriate to the current mode of operation (e.g., that cryptographic
1107 modules are in place when “open,” and secured when “closed,” and for the CA, that all
1108 equipment other than the repository is shut down).
- 1109 • Any security containers are properly secured.
- 1110 • Physical security systems (e.g., door locks, vent covers) are functioning properly.
- 1111 • The area is secured against unauthorized access.

1112 A person or group of persons SHALL be made explicitly responsible for making such checks. When a
1113 group of persons is responsible, a log identifying the person performing a check at each instance SHALL
1114 be maintained. If the facility is not continuously attended, the last person to depart SHALL initial a sign-

1115 out sheet that indicates the date and time and asserts that all necessary physical protection mechanisms are
1116 in place and activated.

1117 **5.1.3 Power and air conditioning**

1118 The CA SHALL have backup capability sufficient to lock out input, finish any pending actions, and
1119 record the state of the equipment automatically before lack of power or air conditioning causes a
1120 shutdown.

1121 The repositories (containing CA certificates and CRLs) SHALL be provided with uninterrupted power
1122 sufficient for a minimum of 6 hours operation in the absence of commercial power, to maintain
1123 availability and avoid denial of service.

1124 **5.1.4 Water exposures**

1125 CA equipment SHALL be installed such that it is not in danger of exposure to water.

1126 **5.1.5 Fire prevention and protection**

1127 No Stipulation

1128 **5.1.6 Media storage**

1129 Media SHALL be stored so as to protect them from accidental damage (e.g., water, fire, or
1130 electromagnetic) and unauthorized physical access.

1131 **5.1.7 Waste disposal**

1132 Sensitive media and documentation that are no longer needed for operations SHALL be destroyed in a
1133 secure manner. For example, sensitive paper documentation SHALL be shredded, burned, or otherwise
1134 rendered unrecoverable.

1135 **5.1.8 Off-site backup**

1136 Full system backups sufficient to recover from system failure SHALL be made on a periodic schedule.
1137 Backups are to be performed and stored off-site not less than once per week. At least one full backup
1138 copy SHALL be stored at an off-site location (separate from CA equipment). Only the latest full backup
1139 need be retained. The backup SHALL be stored at a site with physical and procedural controls
1140 commensurate to that of the operational CA.

1141 **5.2 Procedural controls**

1142 **5.2.1 Trusted roles**

1143 A trusted role is one whose incumbent performs functions that can introduce security problems if not
1144 carried out properly, whether accidentally or maliciously.

1145 The requirements of this policy are defined in terms of four roles. Each CA shall maintain lists, including
1146 names, contact information, and copies of appointment memoranda of those who act in these trusted roles,
1147 and shall make them available during compliance audits. The CA will make this information a part of the
1148 permanent records of the CA. However, the CA shall not maintain personnel or investigative records
1149 requiring protection under the Privacy Act.

- 1150 1. Administrator - authorized to install, configure, and maintain the CA; establish and maintain
1151 accounts; configure profiles and audit parameters; and generate component keys.
- 1152 2. Officer - authorized to request or approve certificates or certificate revocations, and perform the
1153 Validation Specialist functions for quarterly reviews of issued certificates
- 1154 3. Auditor – authorized to review, maintain, and archive audit logs.
- 1155 4. Operator – authorized to perform system backup and recovery.

1156 These four roles are employed at the CA. Separation of duties SHALL comply with 5.2.4, and
1157 requirements for two-person control with 5.2.2, regardless of the titles and numbers of Trusted Roles.

1158 A detailed description of the responsibilities for each role:

1159 The Administrator shall be responsible for:

- 1160 • Installation, configuration, and maintenance of the CA;
- 1161 • Establishing and maintaining CA system accounts;
- 1162 • Configuring certificate profiles or templates and audit parameters, and;
- 1163 • Generating and backing up CA keys.

1164 Administrators shall not issue certificates to subscribers.

1165 The Officer (aka Registration Authority and / or Validation Specialist) shall be responsible for:

- 1166 • Verifying the identity of subscribers and accuracy of information included in certificates pursuant
1167 to Section 3.2
- 1168 • Performing the Validation Specialist functions for quarterly reviews of issued certificates
- 1169 • Approving and executing the issuance of the certificates where inspection of the validation
1170 information is required, and
- 1171 • Requesting, approving and executing the revocation of certificates

1172 The Audit Administrator shall be responsible for:

- 1173 • Reviewing, maintaining, and archiving audit logs;
- 1174 • Performing or overseeing internal compliance audits to ensure that the CA is operating in
1175 accordance with its CPS;

1176 The Operator shall be responsible for the routine operation of the CA equipment and operations such as
1177 system backups and recovery or changing recording media.

1178 **5.2.2 Number of Individuals Required per Task**

1179 The CA Private Key SHALL be backed up, stored, and recovered only by personnel in trusted roles using,
1180 at least, dual control in a physically secured environment.

1181 Where multiparty control is required, at least one of the participants SHALL be an Administrator. All
1182 participants must serve in a trusted role as defined in section 5.2.1. Multiparty control SHALL NOT be
1183 achieved using personnel that serve in the Auditor trusted role.

1184 **5.2.3 Identification and authentication for each role**

1185 An individual SHALL identify and authenticate him/herself before being permitted to perform any
1186 actions set forth above for that role or identity. All Trusted Roles SHALL use a unique credential created
1187 by or assigned to a single person for identification and authentication.

1188 **5.2.4 Roles requiring separation of duties**

1189 Individuals may only assume one of the Officer, Administrator, and Auditor roles, but any individual may
1190 assume the Operator role. The CA software and hardware SHALL identify and authenticate its users and
1191 enforce least privilege. The CA software and hardware SHALL ensure that no user can assume both the
1192 Administrator and Officer roles, assume both the Administrator and Auditor roles, or assume both the
1193 Auditor and Officer roles.

1194 **5.3 Personnel controls**

1195 **5.3.1 Qualifications, experience, and clearance requirements**

1196 All persons filling trusted roles SHALL be selected on the basis of loyalty, trustworthiness, and integrity,
1197 and must be U.S. citizens. The requirements governing the qualifications, selection and oversight of
1198 individuals who operate, manage, oversee, and audit the CA SHALL be set forth in the CPS.

1199 **5.3.2 Background check procedures**

1200 Trusted role personnel SHALL, at a minimum, pass a background investigation covering the following
1201 areas: • Employment; • Education; • Place of residence; • Law Enforcement; and • References. The period
1202 of investigation must cover at least the last five years for each area, excepting the residence check which
1203 must cover at least the last three years. Adjudication of the background investigation SHALL be
1204 performed by a competent adjudication authority using a process consistent with Executive Order 13467
1205 or equivalent.

1206 **5.3.3 Training Requirements and Procedures**

1207 The CA SHALL provide all personnel performing information verification duties with skills-training that
1208 covers basic Public Key Infrastructure knowledge, authentication and vetting policies and procedures
1209 (including the CA's Certificate Policy and/or Certification Practice Statement), common threats to the
1210 information verification process (including phishing and other social engineering tactics), and these
1211 Requirements.

1212 The CA SHALL maintain records of such training and ensure that personnel entrusted with Validation
1213 Specialist duties maintain a skill level that enables them to perform such duties satisfactorily.

1214 The CA SHALL document that each Validation Specialist possesses the skills required by a task before
1215 allowing the Validation Specialist to perform that task.

1216 The CA SHALL require all Validation Specialists to pass an examination provided by the CA on the
1217 information verification requirements outlined in these Requirements.

1218 **5.3.4 Retraining frequency and requirements**

1219 All personnel in Trusted roles SHALL maintain skill levels consistent with the CA's training and
1220 performance programs.

1221 All individuals responsible for PKI roles SHALL be made aware of changes in the CA operation. Any
1222 significant change to the operations SHALL have a training (awareness) plan, and the execution of such
1223 plan SHALL be documented. Examples of such changes are CA software or hardware upgrade, changes
1224 in automated security systems, and relocation of equipment.

1225 Documentation SHALL be maintained identifying all personnel who received training and the level of
1226 training completed.

1227 **5.3.5 Job rotation frequency and sequence**

1228 No Stipulation

1229 **5.3.6 Sanctions for unauthorized actions**

1230 The CA SHALL take appropriate administrative and disciplinary actions against personnel who have
1231 performed actions involving the CA that are not authorized in this CP, the CA CPS, or other published
1232 procedures.

1233 **5.3.7 Independent Contractor Controls**

1234 Delegated Third Party are not allowed under this policy.

1235 Direct contractor personnel employed to operate any part of the CAs or perform functions pertaining to
1236 the infrastructure shall be subject to the same personnel requirements set forth in 5.3.2 of this CP.

1237 **5.3.8 Documentation supplied to personnel**

1238 Documentation sufficient to define duties and procedures for each role SHALL be provided to the
1239 personnel filling that role.

1240 **5.4 Audit logging procedures**

1241 **5.4.1 Types of events recorded**

1242 The CA SHALL record details of the actions taken to process a certificate request and to issue a
1243 Certificate, including all information generated and documentation received in connection with the
1244 certificate request; the time and date; and the personnel involved. The CA SHALL make these records
1245 available to its Qualified Auditor as proof of the CA's compliance with these Requirements.

1246 The CA SHALL record at least the following events:

1247 1. CA key lifecycle management events, including:

1248 a. Key generation, backup, storage, recovery, archival, and destruction; and b. Cryptographic device
1249 lifecycle management events.

1250 1. CA and Subscriber Certificate lifecycle management events, including:

1251 a. Certificate requests, renewal, and re-key requests, and revocation; b. All verification activities
1252 stipulated in these Requirements and the CA's Certification Practice Statement; c. Date, time, phone
1253 number used, persons spoken to, and end results of verification telephone calls; d. Acceptance and
1254 rejection of certificate requests; Frequency of Processing Log e. Issuance of Certificates; and f.
1255 Generation of Certificate Revocation Lists and OCSP entries.

1256 1. Security events, including:

1257 a. Successful and unsuccessful PKI system access attempts; b. PKI and security system actions
1258 performed; c. Security profile changes; d. System crashes, hardware failures, and other anomalies; e.
1259 Firewall and router activities; and f. Entries to and exits from the CA facility.

1260 Log entries MUST include the following elements:

- 1261 1. Date and time of entry;
1262 2. Identity of the person making the journal entry; and
1263 3. Description of the entry.

1264 **5.4.2 Frequency for Processing and Archiving Audit Logs**

1265 Review of the audit log SHALL be required at least once every 60 days.

1266 Such reviews involve verifying that the log has not been tampered with and then briefly inspecting all log
1267 entries, with a more thorough investigation of any alerts or irregularities in the logs. A statistically
1268 significant portion of the security audit data generated by the CA since the last review SHALL be
1269 examined. This amount will be described in the CPS.

1270 All significant events SHALL be explained in an audit log summary. Actions taken as a result of these
1271 reviews SHALL be documented.

1272 **5.4.3 Retention Period for Audit Logs**

1273 Audit logs SHALL be retained on-site until reviewed, in addition to being archived as described in
1274 section 5.5. The individual who removes audit logs from the CA system SHALL be an official different
1275 from the individuals who, in combination, command the CA signature key.

1276 The CA SHALL retain any audit logs generated for at least seven years. The CA SHALL make these
1277 audit logs available to its Qualified Auditor upon request.

1278 **5.4.4 Protection of Audit Log**

1279 The CA SHALL ensure audit logs are unalterable or maintain an integrity mechanism to identify any
1280 changes.

1281 The security audit data SHALL not be open for reading or modification by any human, or by any
1282 automated process, other than those that perform security audit processing. CA system configuration and
1283 procedures must be implemented together to ensure that only authorized people archive or delete security
1284 audit data. Procedures must be implemented to protect archived data from deletion or destruction before
1285 the end of the security audit data retention period (note that deletion requires modification access).
1286 Security audit data SHALL be moved to a safe, secure storage location separate from the location where
1287 the data was generated.

1288 **5.4.5 Audit Log Backup Procedures**

1289 Audit logs and audit summaries SHALL be backed up at least monthly. A copy of the audit log SHALL
1290 be sent off-site on a monthly basis.

1291 **5.4.6 Audit Log Accumulation System (internal vs. external)**

1292 The audit log collection system may or may not be external to the CA system. Automated audit processes
1293 SHALL be invoked at system or application startup, and cease only at system or application shutdown.
1294 Audit collection systems SHALL be configured such that security audit data is protected against loss
1295 (e.g., overwriting or overflow of automated log files). Should it become apparent that an automated audit
1296 system has failed, and the integrity of the system or confidentiality of the information protected by the
1297 system is at risk, operations SHALL be suspended until the problem has been remedied.

1298 **5.4.7 Notification to event-causing subject**

1299 There is no requirement to notify a subject that an event was audited. Real-time alerts are neither required
1300 nor prohibited by this policy.

1301 **5.4.8 Vulnerability assessments**

1302 Additionally, the CA's security program MUST include an annual Risk Assessment that:

- 1303 1. Identifies foreseeable internal and external threats that could result in unauthorized access,
1304 disclosure, misuse, alteration, or destruction of any Certificate Data or Certificate Management
1305 Processes;
- 1306 2. Assesses the likelihood and potential damage of these threats, taking into consideration the
1307 sensitivity of the Certificate Data and Certificate Management Processes; and
- 1308 3. Assesses the sufficiency of the policies, procedures, information systems, technology, and other
1309 arrangements that the CA has in place to counter such threats.

1310 **5.5 Records archival**

1311 CAs operating under this policy must follow either the General Records Schedules established by the
1312 National Archives and Records Administration or an agency-specific schedule as applicable.

1313 5.5.1 Types of records archived

1314 The CA SHALL retain all documentation relating to certificate requests and the verification thereof, and
1315 all Certificates and revocation thereof, for a minimum of 10 years and 6 months after any Certificate
1316 based on that documentation ceases to be valid.

1317 CA archive records SHALL be sufficiently detailed to determine the proper operation of the CA and the
1318 validity of any certificate - including those revoked or expired - issued by the CA. At a minimum, the
1319 following data SHALL be recorded for archive:

- 1320 • CA accreditation (if applicable)
- 1321 • Certificate policy
- 1322 • Certification practice statement
- 1323 • Contractual obligations and other agreements concerning operations of the CA
- 1324 • System and equipment configuration
- 1325 • Modifications and updates to system or configuration
- 1326 • Certificate requests
- 1327 • All certificates issued and/or published
- 1328 • Revocation requests
- 1329 • Subscriber identity authentication data
- 1330 • Subscriber agreements
- 1331 • Documentation of receipt of tokens
- 1332 • All CRLs issued and/or published
- 1333 • Other data or applications to verify archive contents
- 1334 • Compliance Auditor reports
- 1335 • Any changes to the Audit parameters, e.g. audit frequency, type of event audited
- 1336 • Any attempt to delete or modify the Audit logs
- 1337 • Whenever the CA generates a key (Not mandatory for single session or one-time use symmetric
1338 keys)
- 1339 • All changes to the trusted public keys, including additions and deletions
- 1340 • The export of private and secret keys (keys used for a single session or message are excluded)
- 1341 • The approval or rejection of a certificate status change request
- 1342 • Appointment of an individual to a Trusted Role
- 1343 • Destruction of cryptographic modules
- 1344 • All certificate compromise notifications
- 1345 • Remedial action taken as a result of violations of physical security
- 1346 • Violations of Certificate Policy
- 1347 • Violations of Certification Practice Statement

1348 5.5.2 Retention period for archive

1349 The CA SHALL retain all documentation relating to certificate requests and the verification thereof, and
1350 all Certificates and revocation thereof, for a minimum of 10 years and 6 months without any loss of data
1351 after any Certificate based on that documentation ceases to be valid.

1352 5.5.3 Protection of archive

1353 No unauthorized user SHALL be permitted to write to, modify, or delete the archive. For the CA,
1354 archived records may be moved to another medium. The contents of the archive SHALL not be released

1355 except in accordance with the Privacy Act of 1974 (as amended) and applicable Agency policies. Records
1356 of individual transactions may be released upon request of any subscribers involved in the transaction or
1357 their legally recognized agents. Archive media SHALL be stored in a safe, secure storage facility separate
1358 from the CA.

1359 If the original media cannot retain the data for the required period, a mechanism to periodically transfer
1360 the archived data to new media SHALL be defined by the archive site.

1361 Alternatively, a CA operating under this policy may retain data using whatever procedures have been
1362 approved by NARA for that category of documents. Applications required to process the archive data
1363 SHALL be maintained for a period that equals or exceeds the archive requirements for the data.

1364 **5.5.4 Archive backup procedures**

1365 No Stipulation

1366 **5.5.5 Requirements for time-stamping of records**

1367 CA archive records SHALL be automatically time-stamped as they are created. The system clocks used
1368 for time-stamping SHALL be maintained in synchrony with an authoritative time standard.

1369 **5.5.6 Archive collection system (internal or external)**

1370 Archive data may be collected in any expedient manner.

1371 **5.5.7 Procedures to obtain and verify archive information**

1372 Procedures, detailing how to create, verify, package, transmit, and store the CA archive information,
1373 SHALL be published in the CPS.

1374 **5.6 Key changeover**

1375 To minimize risk from compromise of a CA's private signing key, that key may be changed often. From
1376 that time on, only the new key will be used to sign CA and subscriber certificates. If the old private key is
1377 used to sign OCSP responder certificates or CRLs that cover certificates signed with that key, the old key
1378 must be retained and protected.

1379 After a CA performs a Key Changeover, the CA may continue to issue CRLs with the old key until all
1380 certificates signed with that key have expired.

1381 When a CA updates its private signature key and thus generates a new public key, the CA SHALL notify
1382 the FPKI Policy Authority and subscribers of the change.

1383 **5.7 Compromise and disaster recovery**

1384 **5.7.1 Incident and compromise handling procedures**

1385 CA organizations shall have an Incident Response Plan and a Disaster Recovery Plan.

1386 The CA SHALL document a business continuity and disaster recovery procedures designed to notify and
1387 reasonably protect Application Software Suppliers, Subscribers, and Relying Parties in the event of a
1388 disaster, security compromise, or business failure. The CA is not required to publicly disclose its business
1389 continuity plans but SHALL make its business continuity plan and security plans available to the CA's
1390 auditors upon request. The CA SHALL annually test, review, and update these procedures.

1391 The business continuity plan MUST include:

- 1392 1. The conditions for activating the plan,
- 1393 2. Emergency procedures,
- 1394 3. Fallback procedures,
- 1395 4. Resumption procedures,
- 1396 5. A maintenance schedule for the plan;
- 1397 6. Awareness and education requirements;
- 1398 7. The responsibilities of the individuals;
- 1399 8. Recovery time objective (RTO);
- 1400 9. Regular testing of contingency plans.
- 1401 10. The CA's plan to maintain or restore the CA's business operations in a timely manner following
1402 interruption to or failure of critical business processes
- 1403 11. A requirement to store critical cryptographic materials (i.e., secure cryptographic device and
1404 activation materials) at an alternate location;
- 1405 12. What constitutes an acceptable system outage and recovery time
- 1406 13. How frequently backup copies of essential business information and software are taken;
- 1407 14. The distance of recovery facilities to the CA's main site; and
- 1408 15. Procedures for securing its facility to the extent possible during the period of time following a
1409 disaster and prior to restoring a secure environment either at the original or a remote site.

1410 The FPKIPA shall be notified by the CAs operating under this policy of any security incident. A security
1411 incident or incident is defined as a violation or imminent threat of violation of the NPE CP, CPS,
1412 subscriber agreements, MOA, or any other document that governs the operations of the CA. A security
1413 incident may include but is not limited to the following:

- 1414 • Suspected or detected compromise of Certificate Systems
- 1415 • Suspected or detected compromise of a certificate status server (CSS) if:
 - 1416 ○ The CSS certificate has a lifetime of more than 72 hours and
 - 1417 ○ The CSS certificate cannot be revoked (e.g., an OCSP responder certificate with the id-
1418 pkix-ocsp-nocheck extension)
- 1419 • Physical or electronic penetration of the Certificate Systems
- 1420 • Successful denial of service attacks on the Certificate System components
- 1421 • Any incident preventing the CA from issuing a CRL within 48 hours of the issuance of the
1422 previous CRL
- 1423 • Suspected or detected issuance of fraudulent certificates used for unethical purposes such as but
1424 not limited to promoting malware or illegal software.
- 1425 • Any certificate issuance not in compliance with NPE CP, CPS, or NPE Certificate Profiles.
- 1426 • CA private key compromise.
- 1427 • A known or reasonably known, publicly reported compromise of Certificate Systems
- 1428 • Any other issue that the FPKIPA identifies as calling into question the CAs integrity or
1429 trustworthiness

1430 In the event of a CA or certificate compromise or fraudulent mis-issuance, the CA shall notify the
1431 FPKIPA as soon as possible, but no later than 24 hours from the time the incident was discovered. An
1432 initial security incident report shall be submitted to the FPKI@GSA.gov email or communicated directly
1433 to the FPKIPA and include the following sections:

- 1434 1. Which Certificate Systems or components were affected by the incident
- 1435 2. The CA's interpretation of the incident.
- 1436 3. Was the incident detected as part of normal operations. If not, explain why.
- 1437 4. Who detected the incident or perpetrated if known
- 1438 5. When the incident was discovered
- 1439 6. Physical location of the incident, if applicable.
- 1440 7. A partial or complete list of all certificates that were either mis-issued or not compliant with the
1441 CP/CPS as a result of the incident.

1442 A final security incident report shall be submitted at a date specified by the FPKIPA to the same location
1443 as the initial incident report and include all sections identified below.

- 1444 1. A complete timeline of events.
- 1445 2. If a compromise, a detailed description of the exploit and what and how infrastructure was
1446 compromised.
- 1447 3. If the CA did not detect the incident, why not.
- 1448 4. What specific remedial measures were taken or will take to address the underlying cause
1449 including specific CP/CPS updates.
- 1450 5. Other information appropriate to understand the incident such as system or vendor documentation
1451 or other material.
- 1452 6. Proof the mis-issued certificates were revoked.
- 1453 7. Who detected or perpetrated the incident.
- 1454 8. If requested, log files.
- 1455 9. Detailed description of how the incident was closed.

1456 In coordination with the CA, the FPKIPA may conduct the following activities as part of an incident
1457 response.

- 1458 • Communicate with affected parties or directly with affected organizations
- 1459 • Publish notice of revocation
- 1460 • Publicly publish a final security incident report on an approved government website.
- 1461 • Require the CA to employ, at the CA expense, a third party investigator to investigate the security
1462 incident and prepare a final security incident report.
- 1463 • Request specific reports at a periodic interval as determined by the FPKIPA
- 1464 • Specify a due date for the CA to submit a final security incident report.

1465 The FPKIPA shall notify the CA, in writing, of its intentions in response to the security incident seven (7)
1466 days prior to the action by the FPKIPA except under exceptional circumstances (as defined in the
1467 glossary) where the FPKIPA will make reasonable efforts to communicate with the CA prior to taking
1468 action. The CA may propose an alternate course of action and the FPKIPA may consider reasonable
1469 alternatives but reserves the right to reject any proposed course of action not in the government's best
1470 interest.

1471 **Note:** The FPKIPA will follow individual Application Trusted Root Program requirements to report
1472 security concerns.

5.7.2 Recovery Procedures if Computing resources, software, and/or data are corrupted

When computing resources, software, and/or data are corrupted, CAs operating under this policy SHALL respond as follows:

- Before returning to operation, ensure that the system's integrity has been restored.
- If the CA signature keys are not destroyed, CA operation SHALL be reestablished, giving priority to the ability to generate certificate status information within the CRL issuance schedule.
- If the CA signature keys are destroyed, CA operation SHALL be reestablished as quickly as possible, giving priority to the generation of a new CA key pair.

5.7.3 Recovery Procedures after Key Compromise

In the event of a CA private key compromise, the following operations MUST be performed.

- The FPKI Policy Authority SHALL be immediately informed, as well as any superior CAs and any entities known to be distributing the CA certificate.
- The CA MUST generate new keys.
- The superior CA must be revoke the subordinate CA certificate within seven (7) days.
- All subscriber certificates MUST be revoked within twenty-four (24) hours.

If the CA distributed the private key in a Trusted Certificate, the CA SHALL perform the following operations:

- Generate a new Trusted Certificate.
- Securely distribute the new Trusted Certificate
- Initiate procedures to notify subscribers of the compromise.

Subscriber certificates may be renewed automatically by the CA under the new key pair, or the CA may require subscribers to repeat the initial certificate application process.

5.7.4 Business continuity capabilities after a disaster

For the Root CA, recovery procedures SHALL be in place to reconstitute the CA within six (6) hours of failure.

All other CAs operating under this policy SHALL have recovery procedures in place to reconstitute the CA within 72 hours of failure.

In the case of a disaster whereby the CA installation is physically damaged and all copies of the CA signature key are destroyed as a result, the FPKI Policy Authority SHALL be notified at the earliest feasible time, and the FPKI Policy Authority SHALL take whatever action it deems appropriate.

Relying parties may decide of their own volition whether to continue to use certificates signed with the destroyed private key pending reestablishment of CA operation with new certificates.

5.8 CA or RA termination

- 1507 This section does not apply to CAs that have ceased issuing new certificates but are continuing to issue
1508 CRLs until all certificates have expired. Such CAs are required to continue to conform with all relevant
1509 aspects of this policy (e.g., audit logging and archives).
- 1510 When a CA operating under this policy terminates operations before all certificates have expired, the CA
1511 signing keys SHALL be surrendered to the FPKI Policy Authority.
- 1512 Any issued certificates that have not expired, SHALL be revoked and a final long term CRL with a
1513 nextUpdate time past the validity period of all issued certificates SHALL be generated. This final CRL
1514 SHALL be available for all relying parties until the validity period of all issued certificates has passed.
1515 Once the last CRL has been issued, the private signing key(s) of the CA to be terminated will be
1516 destroyed.
- 1517 Prior to CA termination, the CA SHALL provide archived data to an archive facility. As soon as possible,
1518 the CA will advise all other organizations to which it has issued certificates of its termination.

6. TECHNICAL SECURITY CONTROLS

6.1 Key pair generation and installation

6.1.1 Key pair generation

6.1.1.1 CA Key Pair Generation

In all cases, the CA SHALL:

1. prepare and follow a Key Generation Script,
2. have a Qualified Auditor witness the CA Key Pair generation process or record a video of the entire CA Key Pair generation process, and
3. have a Qualified Auditor issue a report opining that the CA followed its key ceremony during its Key and Certificate generation process and the controls used to ensure the integrity and confidentiality of the Key Pair.

In all cases, the CA SHALL:

1. Generate the CA keys in a physically secured environment as described in the CA's Certification Practice Statement;
2. Generate the CA keys using personnel in Trusted Roles under the principles of multiple person control and split knowledge;
3. Generate the CA keys within cryptographic modules that meet or exceed FIPS 140 Level 3 validation;
4. Log its CA key generation activities;
5. Maintain effective controls to provide reasonable assurance that the Private Key was generated and protected in conformance with the procedures described in the Certificate Policy and Certification Practice Statement and its Key Generation Script.

The documentation of the procedure must be detailed enough to show that appropriate role separation was used and the CA key pair generation must create a verifiable audit trail that the security requirements for procedures were followed.

6.1.1.2 RA Key Pair Generation

RAs SHALL NOT generate key pairs.

6.1.1.3 Subscriber Key Pair Generation

The CA SHALL reject a certificate request if the requested Public Key does not meet the requirements set forth in Sections 6.1.5 and 6.1.6 or if it has a known weak Private Key (such as a Debian weak key, see <http://wiki.debian.org/SSLkeys>).

6.1.2 Private key delivery to subscriber

1551 Parties other than the Subscriber SHALL NOT archive the Subscriber Private Key without authorization
1552 by the Subscriber.

1553 Subscribers SHALL generate their own keys in compliance with sections 6.1.5 and 6.1.6.

1554 If the CA or any of its designated RAs become aware that a Subscriber's Private Key has been
1555 communicated to an unauthorized person or an organization not affiliated with the Subscriber, then the
1556 CA SHALL revoke all certificates that include the Public Key corresponding to the communicated Private
1557 Key.

1558 **6.1.3 Public key delivery to certificate issuer**

1559 The public key and the subscriber's identity must be delivered securely to the CA for certificate issuance.
1560 The delivery mechanism shall bind the subscriber's verified identity to the public key. If cryptography is
1561 used to achieve this binding, it must be at least as strong as the CA keys used to sign the certificate.

1562 **6.1.4 CA public key delivery to relying parties**

1563 When a Subordinate CA updates its signature key pair, the CA shall distribute the new public key in a
1564 secure fashion.

1565 The Root CA certificate(s) shall be conveyed to relying parties in a secure fashion to preclude substitution
1566 attacks. Acceptable methods for self-signed Root CA certificate delivery are:

- 1567 • Loading a self-signed certificate onto tokens delivered to relying parties via secure mechanisms;
- 1568 • Secure distribution of self-signed certificates through secure out-of-band mechanisms;
- 1569 • Comparison of the hash of the self-signed certificate against a hash value made available via
1570 authenticated out-of-band sources (note that hashes posted in-band along with the certificate are
1571 not acceptable as an authentication mechanism)

1572 **6.1.5 Key sizes**

1573 Certificates MUST meet the following requirements for algorithm type and key size.

1574 (1) Root CA Certificates

Digest algorithm	SHA-256, SHA-384 or SHA-512
Minimum RSA modulus size (bits)	4096
ECC curve	NIST P-256, P-384, or P-521
Minimum DSA modulus and divisor size (bits)***	L= 2048 N= 224 or L= 2048 N= 256

1575 (2) Subordinate CA Certificates

Digest algorithm	SHA-256, SHA-384 or SHA-512

Minimum RSA modulus size (bits)	2048
ECC curve	NIST P-256, P-384, or P-521
Minimum DSA modulus and divisor size (bits)***	L= 2048 N= 224 or L= 2048 N= 256

1576 (3) Subscriber Certificates

Digest algorithm	SHA-256, SHA-384 or SHA-512
Minimum RSA modulus size (bits)	2048
ECC curve	NIST P-256, P-384, or P-521
Minimum DSA modulus and divisor size (bits)***	L= 2048 N= 224 or L= 2048 N= 256

1577 *** L and N (the bit lengths of modulus p and divisor q, respectively) are described in the Digital
 1578 Signature Standard, FIPS 186-4 (<http://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.186-4.pdf>).

1579 6.1.6 Public key parameters generation and quality checking

1580 RSA: The CA SHALL confirm that the value of the public exponent e shall be an odd positive integer
 1581 such that:

1582 $\bullet \quad 2^{16} < e < 2^{256}$

1583 The modulus SHALL also have the following characteristics: an odd number, not the power of a prime,
 1584 and have no factors smaller than 752. [Source: NIST SP 800-89 and NIST FIPS 186-4]

1585 ECC: The CA SHOULD confirm the validity of all keys using either the ECC Full Public Key Validation
 1586 Routine or the ECC Partial Public Key Validation Routine. [Source: Sections 5.6.2.3.2 and 5.6.2.3.3,
 1587 respectively, of NIST SP 800-56A: Revision 2]

1588 6.1.7 Key usage purposes (as per X.509 v3 key usage field)

1589 Root CA Private Keys SHALL NOT be used to sign Certificates except in the following cases:

- 1590 1. Self-signed Certificates to represent the Root CA itself;
- 1591 2. Certificates for Subordinate CAs and Cross Certificates;
- 1592 3. Certificates for infrastructure purposes (administrative role certificates, internal CA operational
 1593 device certificates); and
- 1594 4. Certificates for OCSP Response verification.

1595 6.2 Private Key Protection and Cryptographic Module 1596 Engineering Controls

1597 The CA SHALL implement physical and logical safeguards to prevent unauthorized certificate issuance.
1598 Protection of the CA Private Key outside the validated system or device specified above MUST consist of
1599 physical security, encryption, or a combination of both, implemented in a manner that prevents disclosure
1600 of the Private Key. The CA SHALL encrypt its Private Key with an algorithm and key-length that,
1601 according to the state of the art, are capable of withstanding cryptanalytic attacks for the residual life of
1602 the encrypted key or key part.

1603 **6.2.1 Cryptographic module standards and controls**

1604 The relevant standard for cryptographic modules is Security Requirements for Cryptographic Modules
1605 [FIPS 140-2]. Cryptographic modules shall be validated to a FIPS 140 level identified in this section.

- 1606 • Cryptographic modules for CAs and OCSP responders SHALL be hardware modules validated as
1607 meeting FIPS 140-2 Level 3 or above

1608 **6.2.2 Private key (n out of m) multi-person control**

1609 For all CAs:

- 1610 • A single person shall not be permitted to activate or access any cryptographic module that
1611 contains the complete CA private signing key.
- 1612 • CA signature keys may be backed up only under at least two-person control.
- 1613 • Access to CA signing keys backed up for disaster recovery shall be under at least two-person
1614 control.
- 1615 • The names of the parties used for two-person control shall be made available for inspection
1616 during Qualified Audits.

1617 **6.2.3 Private key escrow**

1618 For all CAs:

- 1619 • The CA private keys SHALL never be escrowed

1620 **6.2.4 Private key backup**

1621 For all CAs:

- 1622 • The CA private signature keys SHALL be backed up under the same multiperson control as the
1623 original signature key.
- 1624 • At least one copy of the private signature key shall be stored off-site.
- 1625 • All copies of the CA private signature key shall be accounted for and protected in the same
1626 manner as the original.
- 1627 • Backup procedures shall be included in the CA's CPS

1628 See Section 5.2.2.

1629 **6.2.5 Private key archival**

1630 Parties other than the Subordinate CA SHALL NOT archive the Subordinate CA Private Keys.

1631 **6.2.6 Private key transfer into or from a cryptographic module**

1632 All CAs shall generate their own keys in FIPS 140 validated cryptographic modules, in compliance with
1633 sections 6.1.5 and 6.1.6. CA private keys may be exported from the cryptographic module only to
1634 perform CA key backup procedures as described in section 6.2.4.1. At no time shall the CA private key
1635 exist in plaintext outside the cryptographic module. Private or symmetric keys used to encrypt other
1636 private keys for transport must be protected from disclosure.

1637 If the Issuing CA becomes aware that a Subordinate CA's Private Key has been communicated to an
1638 unauthorized person or an organization not affiliated with the Subordinate CA, then the Issuing CA
1639 SHALL revoke all certificates that include the Public Key corresponding to the communicated Private
1640 Key.

1641 **6.2.7 Private key storage on cryptographic module**

1642 All CAs SHALL protect their Private Keys in a system or device that has been validated as meeting at
1643 least FIPS 140 level 3 which includes requirements to protect the Private Key and other assets against
1644 known threats.

1645 **6.2.8 Activating Private Keys**

1646 For the Root CA(s), signing key activation MUST implement multiparty control as specified in Section
1647 5.2.2.

1648 **6.2.9 Deactivating Private Keys**

1649 Cryptographic modules that have been activated shall not be available to unauthorized access. After use,
1650 the cryptographic module shall be deactivated, e.g., via a manual logout procedure or automatically after
1651 a period of inactivity as defined in the CA's CPS. CA cryptographic modules SHALL be removed and
1652 stored in a secure container when not in use.

1653 **6.2.10 Destroying Private Keys**

1654 Individuals in trusted roles shall destroy all CA and OCSP private signature keys when the keys are no
1655 longer needed. All CAs operating under this policy shall document the private key destruction methods in
1656 their Certificate Practices Statement.

1657 **6.2.11 Cryptographic Module Capabilities**

1658 See Section 6.2.1

1659 **6.3 Other aspects of key pair management**

1660 **6.3.1 Public key archival**

1661 No stipulation.

1662 **6.3.2 Certificate operational periods and key pair usage periods**

1663 Root CA Certificates SHALL have a Validity Period no greater than 20 years. Subordinate CA
1664 Certificates SHALL have a Validity Period no greater than 10 years. All certificates signed by a specific
1665 CA key pair must expire before the end of that key pair's usage period.

1666 All Subscriber Certificates SHALL have a Validity Period no greater than 825 days.
1667 Subscriber Certificates issued for delegated OCSP responders SHALL have a Validity Period no greater
1668 than 45 days.

1669 **6.4 Activation data**

1670 **6.4.1 Activation data generation and installation**

1671 CA activation data may be user-selected by each of the multiple parties holding that activation data. If the
1672 activation data must be transmitted, it shall be via an appropriately protected channel, and distinct in time
1673 and place from the associated cryptographic module.

1674 **6.4.2 Activation data protection**

1675 For all CAs, this CP makes no further stipulation beyond that specified in FIPS 140.

1676 **6.4.3 Other aspects of activation data**

1677 No stipulation.

1678 **6.5 Computer security controls**

1679 **6.5.1 Specific computer security technical requirements**

1680 Administrator privileges to all Certificate System components SHALL only be granted to the
1681 Administrator trusted role.

1682 All CAs SHALL implement multifactor authentication for all Trusted Role accounts capable of directly
1683 causing certificate issuance or authenticating to Certificate Systems. All Trusted Roles SHALL use a
1684 unique credential created by or assigned to a single person for identification and authentication.

1685 All CAs SHALL implement multifactor authentication for all access to component systems including
1686 operating system and software.

1687 For all CAs and component systems including certificate status services operating under this policy, the
1688 computer security functions listed below are required. These functions may be provided by the operating
1689 system, or through a combination of operating system, software, and physical safeguards. The CA and its
1690 ancillary parts SHALL include the following functionality:

- 1691 • be configured to remove or disable all accounts, applications, services, protocols, and ports that
- 1692 are not used in the CA's operations;
- 1693 • authenticate the identity of users before permitting access to the system or applications;
- 1694 • manage privileges of users to limit users to their assigned roles and implement least privilege
- 1695 controls;
- 1696 • generate and archive audit records for all transactions; (see section 5.4)
- 1697 • enforce domain integrity boundaries for security critical processes;
- 1698 • support recovery from key or system failure; and

1699 For remote workstations used to administer the CAs, the computer security functions listed below are
1700 required:

- 1701 • authenticate the identity of users before permitting access to the system or applications;
- 1702 • manage privileges of users to limit users to their assigned roles;
- 1703 • generate and archive audit records for all transactions; (see section 5.4)
- 1704 • enforce domain integrity boundaries for security critical processes; and
- 1705 • support recovery from key or system failure; and
- 1706 • configure workstations with inactivity time-outs to enforce account log out or lock the
- 1707 workstation when no longer in use;

1708 All communications between any PKI trusted role and the CA shall be authenticated and protected from
1709 modification.

1710 **6.5.2 Computer security rating**

1711 No Stipulation.

1712 **6.6 Life cycle technical controls**

1713 **6.6.1 System development controls**

1714 The system development controls for all CAs and any Registration Authority functions listed below are
1715 required:

- 1716 • The CA hardware and software shall be dedicated to performing one task: the CA. There shall be
- 1717 no other applications, hardware devices, network connections, or component software installed
- 1718 that are not part of the CA operation. Where the CA operation supports multiple CAs, the
- 1719 hardware platform may support multiple CAs.
- 1720 • Hardware and software procured to operate the CA shall be purchased in a fashion to reduce the
- 1721 likelihood that any particular component was tampered with (e.g., by ensuring the random
- 1722 selection of material at time of purchase or installation).
- 1723 • Hardware and software shall be similarly limited and scanned for malicious code on first use and
- 1724 continuously thereafter.

1725 **6.6.2 Security management controls**

1726 The security management controls for all CAs and any Registration Authority functions listed below
1727 SHALL be implemented:

- 1728 • The configuration of the CA system, in addition to any modifications and upgrades, SHALL be
1729 documented and controlled.
- 1730 • Configurations SHALL be reviewed on at least a weekly basis to determine whether any changes
1731 violated the CA's security policies.
- 1732 • There SHALL be a mechanism for detecting unauthorized modification to the software or
1733 configuration. Configurations SHALL be reviewed on at least a weekly basis to determine
1734 whether any changes violated the CA's security policies.
- 1735 • All system and trusted role accounts SHALL be reviewed at least every ninety (90) days. Any
1736 account that is no longer in use or necessary for operations SHALL be deactivated.
- 1737 • A process SHALL be implemented that disables physical and logical access to a Certificate
1738 System by either a privileged user or a trusted role within 24 hours upon termination of the
1739 individual's employment or contracting relationship with the CA.
- 1740 • All authentication credentials for any account or trusted role on a Certificate System SHALL be
1741 changed whenever authorization to access the account is changed or revoked.

1742 6.6.3 Life cycle security controls

- 1743 • Hardware and software shall be scanned for vulnerabilities at least every thirty (30) days
- 1744 • Critical vulnerabilities shall be patched within thirty (30) days or less
- 1745 • High vulnerabilities shall be patched within sixty (60) days or less
- 1746 • CAs including Repositories and any Registration Authority system functions shall undergo
1747 penetration testing every ninety (90) days

1748 6.7 Network security controls

1749 Secure Zones are a physical or logical separation of Certificate Systems while a High Security Zone is a
1750 physical area where a private key or cryptographic equipment is stored. Each Zone is protected
1751 commensurate with its level of assurance. A High Security Zone may exist within a Secure Zone that is
1752 physically or logically separated from other Secure Zones.

1753 For the Root CA, the CA SHALL be operated in a High Security Zone and in an offline (powered off,
1754 disconnected) or air-gapped (powered on, disconnected) state from all other networks.

1755 For all CAs and any Registration Authority functions, the network security controls listed below are
1756 required:

- 1757 • Secure Zones shall be implemented to secure Certificate Systems based on functional, logical,
1758 and physical (including location) relationships.
- 1759 • The same security controls SHALL be applied to all systems co-located in the same Zone with a
1760 Certificate System.
- 1761 • Security support systems SHALL be configured to protect systems and communications between
1762 systems inside Secure Zones and High Security Zones as well as with non-Certificate Systems to
1763 Delegated Third Parties, Public Networks, and other business partners.
- 1764 • Only trusted roles SHALL have access to Secure and High Security Zones.
- 1765 • A network guard, firewall, or filtering router shall protect network access to CA equipment.
- 1766 • The network guard, firewall, or filtering router shall limit services allowed to and from the CA
1767 equipment to those required to perform CA functions.
- 1768 • Protection of CA equipment shall be provided against known network attacks.

- 1769 • All unused network ports and services shall be turned off. Any network software present on the
1770 CA equipment shall be necessary to the functioning of the CA application.
- 1771 • Any boundary control devices used to protect the network on which equipment is hosted shall
1772 deny all but the necessary services to the equipment.
- 1773 • Repositories, certificate status servers, and remote workstations used to administer the CAs shall
1774 employ appropriate network security controls.
- 1775 • Networking equipment shall turn off unused network ports and services.
- 1776 • Any network software present shall be necessary to the functioning of the equipment.
- 1777 • The CA shall establish connection with a remote workstation used to administer the CA only after
1778 successful authentication of the remote workstation at a level of assurance commensurate with
1779 that of the CA. Remote connections shall be restricted, except when:
 - 1780 ○ the remote connection originates from a device owned by the CA and from a pre-
1781 approved IP address;
 - 1782 ○ the connection is through a temporary, non-persistent and encrypted channel that is
1783 supported by multifactor authentication;
 - 1784 ○ only allow connections through a designated intermediary device when the device is:
 - 1785 ▪ located within the CA's network;
 - 1786 ▪ secured according to this CP; and
 - 1787 ▪ mediates the remote connection.

1788 6.8 Time-stamping

- 1789 Asserted times shall be accurate to within three minutes. Electronic or manual procedures may be used to
1790 maintain system time. Clock adjustments are auditable events (see section 5.4.1).

7. CERTIFICATE, CRL, AND OCSP PROFILES

7.1 Certificate profile

The CA SHALL meet the technical requirements set forth in Section 2.2 - Publication of Information, Section 6.1.5 - Key Sizes, and Section 6.1.6 - Public Key Parameters Generation and Quality Checking.

CAs SHALL generate non-sequential Certificate serial numbers greater than zero (0) containing at least 64 bits (minimum of 8 octets) of output from a CSPRNG, not to exceed 20 octets.

7.1.1 Version number(s)

Certificates SHALL be of type X.509 v3.

7.1.2 Certificate Content and Extensions; Application of RFC 5280

This section specifies the additional requirements for Certificate content and extensions for Certificates generated after the Effective Date.

7.1.2.1 Root CA Certificate

a. basicConstraints (required)

Required/Optional: Required

This extension SHALL appear as a critical extension. The cA field SHALL be set true. The pathLenConstraint field SHALL NOT be present.

b. keyUsage (required)

Required/Optional: Required

This extension SHALL be present and MUST be marked critical. Bit positions for keyCertSign and cRLSign SHALL be set. If the Root CA Private Key is used for signing OCSP responses, then the digitalSignature bit MUST be set.

c. certificatePolicies

Required/Optional/Prohibited: Prohibited

This extension SHALL NOT be present.

d. extendedKeyUsage

Required/Optional/Prohibited: Prohibited

This extension SHALL NOT be present.

e. Subject Information / Subject Distinguished Name (required)

Required/Optional: Required See Section 7.1.4.3.1

7.1.2.2 Subordinate CA Certificate

1822 **a. certificatePolicies (required)**

1823 **Required/Optional:** Required

1824 This extension SHALL be present and SHOULD NOT be marked critical.

1825 **certificatePolicies:policyIdentifier (required)**

1826 **Required/Optional:** Required

1827 **b. cRLDistributionPoints (required)**

1828 **Required/Optional:** Required

1829 This extension SHALL be present and SHALL NOT be marked critical. It SHALL contain the HTTP
1830 URL of the CA's CRL service. The HTTP URL included must be publicly accessible on the Internet.

1831 **c. authorityInformationAccess (required)**

1832 **Required/Optional:** Required

1833 This extension SHALL be present. It SHALL NOT be marked critical, and it SHALL contain the HTTP
1834 URL of the Issuing CA's OCSP responder (accessMethod = 1.3.6.1.5.5.7.48.1). It SHALL also contain
1835 the HTTP URL of the Issuing CA's certificate (accessMethod = 1.3.6.1.5.5.7.48.2). At least one instance
1836 of the Id-ad-caIssuers accessMethod (accessMethod = 1.3.6.1.5.5.7.48.2) must be publicly accessible on
1837 the Internet and the artifacts served shall be in a BER or DER encoded "certs-only" CMS message as
1838 specified in [RFC2797]

1839 **d. basicConstraints (required)**

1840 **Required/Optional:** Required

1841 This extension SHALL be present and SHALL be marked critical. The cA field SHALL be set true. The
1842 pathLenConstraint field SHALL NOT be present.

1843 **e. keyUsage (required)**

1844 **Required/Optional:** Required

1845 This extension SHALL be present and SHALL be marked critical. Bit positions for keyCertSign and
1846 cRLSign MUST be set. If the Subordinate CA Private Key is used for signing OCSP responses, then the
1847 digitalSignature bit MUST be set.

1848 **f. nameConstraints (required)**

1849 **Required/Optional:** Required

1850 This extension SHALL be present. This extension SHALL be marked critical. See section 7.1.5.

1851

1852 **g. extkeyUsage (required)**

1853 **Required/Optional:** Required

1854 This extension SHALL be present. This extension SHALL be marked non-critical.

1855 All Subordinate CA Certificates are to be Technically constrained in accordance with section 7.1.5. The
1856 value id-kp-serverAuth [RFC5280] MUST be present, and the id-kp-clientAuth [RFC5280] MAY be
1857 present.

1858 Other values MAY be present consistent with use for server authentication, with approval by the FPKI
1859 PA.

1860 **h. Subject Information / Subject Distinguished Name (required)**

1861 **Required/Optional:** Required

1862 See Section 7.1.4.3.1

1863 **7.1.2.3 Subscriber Certificate**

1864 **a. certificatePolicies (required)**

1865 **Required/Optional:** Required

1866 This extension SHALL be present and SHOULD NOT be marked critical.

1867 **certificatePolicies:policyIdentifier (required)**

1868 **Required/Optional:** Required

1869 A Policy Identifier, defined by the issuing CA, that indicates a Certificate Policy asserting the issuing
1870 CA's adherence to and compliance with these Requirements.

1871 **certificatePolicies:policyQualifiers:policyQualifierId (optional)**

1872 **Required/Optional:** Optional

1873 The extension SHOULD be present and is Recommended.

- 1874
 - id-qt 1 [RFC 5280].

1875 **certificatePolicies:policyQualifiers:qualifier:cPSuri (optional)**

1876 **Required/Optional:** Optional

1877 HTTP URL for the Subordinate CA's Certification Practice Statement, Relying Party Agreement or other
1878 pointer to online information provided by the CA.

1879 **b. cRLDistributionPoints (required)**

1880 **Required/Optional:** Required

1881 This extension SHALL be present. It SHALL NOT be marked critical, and it SHALL contain the HTTP
1882 URL of the Issuing CA's CRL service.

1883 **c. authorityInformationAccess (required)**

1884 **Required/Optional:** Required

1885 This extension SHALL be present. It SHALL NOT be marked critical, and it SHALL contain the HTTP
1886 URL of the Issuing CA's OCSP responder (accessMethod = 1.3.6.1.5.5.7.48.1). It SHALL also contain
1887 the HTTP URL of the Issuing CA's certificate (accessMethod = 1.3.6.1.5.5.7.48.2).

1888 **d. basicConstraints (required)**

1889 **Required/Optional:** Required

1890 This extension SHALL be present. The cA field SHALL NOT be true.

1891 **e. keyUsage (required)**

1892 **Required/Optional:** Required

1893 This extension SHALL be present and SHALL be marked critical.

1894 Subscriber certificates used for server authentication SHALL include digitalSignature, and MAY include
1895 keyEncipherment and / or keyAgreement.

1896 **f. extKeyUsage (required)**

1897 **Required/Optional:** Required

1898 This extension SHALL be present. It SHALL NOT be marked critical.

1899 Either the value id-kp-serverAuth [RFC5280] or id-kp-clientAuth [RFC5280] or both values SHALL be
1900 present. id-kp-emailProtection [RFC5280] and anyEKU SHALL NOT be present.

1901 Other values SHOULD NOT be present. Other values MAY be present consistent with use for server
1902 authentication, with approval by the FPKI PA.

1903 **7.1.2.4 All Certificates**

1904 All other fields and extensions SHALL be set in accordance with RFC 5280. The CA SHALL NOT issue
1905 a Certificate that contains a keyUsage flag, extendedKeyUsage value, Certificate extension, or other data
1906 not specified in section 7.1.2.1, 7.1.2.2, or 7.1.2.3 unless the CA is aware of a reason for including the
1907 data in the Certificate and receives approval from the Policy Authority.

1908 CAs SHALL NOT issue a Certificate with:

1909 a. Extensions that do not apply in the context of the public Internet (such as an extendedKeyUsage value
1910 for a service that is only valid in the context of a privately managed network), unless:
1911 i. such value falls within an OID arc for which the Applicant demonstrates ownership, or
1912 ii. the Applicant can otherwise demonstrate the right to assert the data in a public context; or

1913 b. semantics that, if included, will mislead a Relying Party about the certificate information verified by
1914 the CA (such as including extendedKeyUsage value for a smart card, where the CA is not able to verify
1915 that the corresponding Private Key is confined to such hardware due to remote issuance).

1916 **7.1.2.5 Application of RFC 5280**

1917 For purposes of clarification, a Precertificate, as described in RFC 6962 - Certificate Transparency, shall
1918 not be considered to be a “certificate” subject to the requirements of RFC 5280 - Internet X.509 Public
1919 Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile under this Certificate Policy
1920 and the CA/Browser Forum Baseline Requirements.

1921 **7.1.3 Algorithm object identifiers**

1922 CAs SHALL NOT issue Subscriber Certificates utilizing the SHA-1 hash algorithm.

1923 **7.1.4 Name forms**

1924 **7.1.4.1 Issuing CA Certificate Subject**

1925 The content of the Certificate Issuer Distinguished Name field SHALL match the Subject Distinguished
1926 Name of the Issuing CA to support Name chaining as specified in RFC 5280, section 4.1.2.4.

1927 CA Subject Distinguished Name SHALL conform to PrintableString string type in ASN.1 notation.

1928 **7.1.4.2 Subject Information for Standard Server Authentication certificates**

1929 By issuing the Certificate, the CA represents that it followed the procedure set forth in this Certificate
1930 Policy and the CA Certification Practice Statement to verify that, as of the Certificate’s issuance date, all
1931 of the Subject Information was accurate.

1932 CAs SHALL NOT include IP Address in a Subject attribute. CAs SHALL NOT include a Domain Name
1933 in a Subject attribute except as specified in Section 3.2.2.4.

1934 **7.1.4.2.1 Subject Alternative Name Extension**

1935 **Certificate Field:** extensions:subjectAltName

1936 **Required/Optional/Prohibited:** Required

1937 **Contents:** This extension MUST contain at least one entry. Each entry MUST be a dNSName containing
1938 the Fully-Qualified Domain Name of a server. The CA MUST confirm that the Applicant controls the
1939 Fully-Qualified Domain Name or has been granted the right to use it by the Domain Name Registrant, as
1940 appropriate. This extension SHALL NOT include IP Address. This extension SHALL NOT include any
1941 Internal Name values.

1942 Wildcard FQDNs are permitted.

1943 **7.1.4.2.2. Subject Distinguished Name Fields**

1944 a. **Certificate Field:** subject:commonName (OID 2.5.4.3)

1945 **Required/Optional/Prohibited:** Required

1946 **Contents:** This field SHALL contain a Fully-Qualified Domain Name that is one of the values contained
1947 in the Certificate's subjectAltName extension (see Section 7.1.4.2.1).

1948 b. **Certificate Field:** subject:organizationName (OID 2.5.4.10)

1949 **Required/Optional/Prohibited:** Optional

1950 **Contents:** If present, the subject:organizationName field SHALL contain U.S. Government (o=U.S.
1951 Government).

1952 c. **Certificate Field:** subject:givenName (2.5.4.42) and subject:surname (2.5.4.4)

1953 **Required/Optional/Prohibited:** Prohibited

1954 d. **Certificate Field:** Number and street: subject:streetAddress (OID: 2.5.4.9)

1955 **Required/Optional/Prohibited:** Prohibited

1956 e. **Certificate Field:** subject:localityName (OID: 2.5.4.7)

1957 **Required/Optional/Prohibited:** Prohibited

1958 f. **Certificate Field:** subject:stateOrProvinceName (OID: 2.5.4.8)

1959 **Required/Optional/Prohibited:**

1960 Required if subject:organizationName is present.

1961 Prohibited if the subject:organizationName is absent.

1962 **Contents:** If present, the subject:stateOrProvinceName field MUST contain the Subject's state or
1963 province information as verified under Section 3.2.2.1. The subject:stateOrProvinceName field SHALL
1964 contain District of Columbia.

1965 g. **Certificate Field:** subject:postalCode (OID: 2.5.4.17)

1966 **Required/Optional/Prohibited:** Prohibited

1967 h. **Certificate Field:** subject:countryName (OID: 2.5.4.6)

1968 **Required/Optional/Prohibited:** Required if subject:organizationName is present.

1969 Optional if subject:organizationName is absent.

1970 **Contents:** If present, the subject:countryName SHALL contain the two-letter ISO 3166-1 country code of
1971 “US” associated with the location of the Subject verified under Section 3.2.2.1.

1972 i. **Certificate Field:** subject:organizationalUnitName

1973 **Required/Optional/Prohibited:** Prohibited

1974 j. **Other Subject Attributes**

1975 All other optional attributes, for the subject field, SHALL NOT be included. Optional attributes MUST
1976 NOT contain metadata such as ‘.’, ‘-’, and ‘ ’ (i.e. space) characters, and/or any other indication that the
1977 value is absent, incomplete, or not applicable.

1978 7.1.4.3. Subject Information - Root Certificates and Subordinate CA Certificates

1979 By issuing a Subordinate CA Certificate, the CA represents that it followed the procedure set forth in its
1980 Certificate Policy and/or Certification Practice Statement to verify that, as of the Certificate’s issuance
1981 date, all of the Subject Information was accurate.

1982 • Examples of Subject Distinguished Names for Root Certificates and Subordinate CA Certificates:

1983 ○ cn=U.S. Federal Device Root CA1, o=U.S. Government, c=US

1984 ○ cn=U.S. Federal Device Issuing CA1, o=U.S. Government, c=US

1985 7.1.4.3.1 Subject Distinguished Name Fields

1986 a. **Certificate Field:** subject:commonName (OID 2.5.4.3)

1987 **Required/Optional:** Required

1988 **Contents:** This field SHALL be present and the contents SHALL be an identifier for the certificate such
1989 that the certificate’s Name is unique across all certificates issued by the issuing certificate.

1990 b. **Certificate Field:** subject:organizationName (OID 2.5.4.10)

1991 **Required/Optional:** Required

1992 **Contents:** This field SHALL be present and SHALL contain U.S. Government (o=U.S. Government).

1993 c. **Certificate Field:** subject:countryName (OID: 2.5.4.6)

1994 **Required/Optional:** Required

1995 **Contents:** This field SHALL contain C=US

1996 CA Certificate Subjects SHALL NOT include organizationalUnit unless approved by the Policy
1997 Authority.

1998 All other optional attributes, for the CA Certificate Subject fields, SHALL NOT be included. Optional
1999 attributes MUST NOT contain metadata such as ‘.’, ‘-’, and ‘ ’ (i.e. space) characters, and/or any other
2000 indication that the value is absent, incomplete, or not applicable.

2001 7.1.5 Name constraints

2002 All Subordinate CA Certificates SHALL be Technically Constrained.

2003 For a Subordinate CA Certificate to be considered Technically Constrained, the certificate SHALL
2004 include an Extended Key Usage (EKU) extension specifying all extended key usages that the Subordinate
2005 CA Certificate is authorized to issue certificates for. The anyExtendedKeyUsage KeyPurposeId SHALL
2006 NOT appear within this extension.

2007 The Subordinate CA Certificate(s) SHALL include the id-kp-serverAuth extended key usage, and the
2008 Subordinate CA Certificate(s) SHALL include the Name Constraints X.509v3 extension with constraints
2009 on dNSName as follows:

2010 a. For each dNSName in permittedSubtrees, the CA MUST confirm that the Applicant has registered the
2011 dNSName or has been authorized by the domain registrant to act on the registrant's behalf in line with the
2012 verification practices of section 3.2.2.4. The Subordinate CA Certificate MUST include at least one
2013 dNSName in permittedSubtrees. The permittedSubtrees for dNSName MUST be within the constraints of
2014 the top-level domains for:

- 2015 • gov (DotGov)
- 2016 • mil (DotMil)

2017 The permittedSubtrees for dNSName MUST NOT contain any other dnsName ranges outside of the the
2018 DotGov or DotMil top-level domains.

2019 b. For ipAddress, Subordinate CAs SHALL NOT issue subscriber certificates with an ipAddress. The
2020 Subordinate CA Certificate SHALL specify the entire IPv4 and IPv6 address ranges in excludedSubtrees.
2021 The Subordinate CA Certificate SHALL include within excludedSubtrees an ipAddress GeneralName of
2022 8 zero octets (covering the IPv4 address range of 0.0.0.0/0). The Subordinate CA Certificate SHALL also
2023 include within excludedSubtrees an ipAddress GeneralName of 32 zero octets (covering the IPv6 address
2024 range of ::0/0).

2025 c. For DirectoryName, Subordinate CAs SHALL NOT issue subscriber certificates with DirectoryName.

2026 A decoded example for issuance to the domain and sub domains of .mil (DotMil) by organization:-
2027 Example Department of Defense would be:-

2028 X509v3 Name Constraints:
2029 Permitted:
2030 DNS:mil
2031 Excluded:
2032 IP:0.0.0.0/0.0.0.0
2033 IP:0:0:0:0:0:0:0:0/0:0:0:0:0:0:0:0:0

2034 A decoded example for issuance to the domain and sub domains of both .gov (DotGov) and .mil (DotMil)
2035 by organization:- Example Department of Defense would be:-

2036 X509v3 Name Constraints:
2037 Permitted:
2038 DNS:mil
2039 DNS:gov
2040 Excluded:
2041 IP:0.0.0.0/0.0.0.0
2042 IP:0:0:0:0:0:0:0:0/0:0:0:0:0:0:0:0:0

2043 7.1.6 Certificate policy object identifier

2044 7.1.6.1. Reserved Certificate Policy Identifiers

2045 This section describes the content requirements for the Root CA, Subordinate CA, and Subscriber
2046 Certificates, as they relate to the identification of Certificate Policy.

2047 The following Certificate Policy identifiers are registered under the CA/Browser Forum and reserved for
2048 use. These Certificate Policy Identifiers are a **required** means of asserting compliance with the
2049 CA/Browser Forum Baseline Requirements as follows:

- 2050 • Domain Validated:
 - 2051 ○ {joint-iso-itu-t(2) international-organizations(23) ca-browser-forum(140) certificate-
 - 2052 policies(1) baseline-requirements(2) domain-validated(1)} (2.23.140.1.2.1),
 - 2053 ○ if the Certificate complies with these Requirements but lacks Subject Identity
 - 2054 Information that is verified in accordance with Section 3.2.2.1 or Section 3.2.3.

2055 If the Certificate asserts the policy identifier of 2.23.140.1.2.1, then it SHALL NOT include
2056 organizationName, givenName, surname, streetAddress, localityName, stateOrProvinceName, or
2057 postalCode in the Subject field.

- 2058 • Organization Validated:
 - 2059 ○ {joint-iso-itu-t(2) international-organizations(23) ca-browser-forum(140) certificate-
 - 2060 policies(1) baseline-requirements(2) organization-validated(2)} (2.23.140.1.2.2),
 - 2061 ○ if the Certificate complies with these Requirements and includes Subject Identity
 - 2062 Information that is verified in accordance with Section 3.2.2.1.

2063 If the Certificate asserts the policy identifier of 2.23.140.1.2.2, then it SHALL also include
2064 organizationName, stateOrProvinceName and countryName in the Subject field in accordance with
2065 Section 7.1.4.2.2. All information shall be verified in accordance with Section 3.2.2.1.

2066 Certificates under this policy SHALL NOT assert the Individual Validated Certificate Policy identifiers
2067 reserved by the CA/Browser Forum.

- 2068 • {joint-iso-itu-t(2) international-organizations(23) ca-browser-forum(140) certificate-policies(1)
2069 baseline-requirements(2) individual-validated(3)} (2.23.140.1.2.3)

2070 7.1.6.2. Root CA Certificates

2071 A Root CA Certificate SHALL NOT contain the certificatePolicies extension.

2072 7.1.6.3 Subordinate CA Certificates

2073 All Subordinate CA's SHALL be an Affiliate as defined in this CP.

2074 A Certificate issued to a Subordinate CA:

- 2075 1. SHALL include the CA/B Forum reserved identifiers to indicate the Subordinate CA's
2076 compliance with the CA/Browser Forum Baseline Requirements, and

2077 2. SHALL include an identifier defined in Section 1.2 to indicate the Subordinate CA's compliance
2078 with this Policy

2079 A Subordinate CA SHALL represent, in its Certification Practice Statement, that all Certificates
2080 containing a policy identifier indicating compliance with the CA/Browser Forum Baseline Requirements
2081 are issued and managed in accordance with the CA/Browser Forum Baseline Requirements. A
2082 Subordinate CA SHALL represent, in its Certification Practice Statement, that all Certificates containing
2083 a policy identifier indicating compliance with this Certificate Policy are issued and managed in
2084 accordance with this Certificate Policy.

2085 **7.1.6.4 Subscriber Certificates**

2086 A Certificate issued to a Subscriber SHALL contain one policy identifier, defined by this CP in Section
2087 1.2, in the Certificate's certificatePolicies extension that indicates adherence to and compliance with this
2088 Certificate Policy. CAs SHALL also assert one of the CA/B Forum Reserved Policy OIDs in such
2089 Certificates.

2090 Subscriber certificates SHALL contain certificate policy identifier(s) for either domain validated policies
2091 or organization validated policies but SHALL NOT assert certificate policy identifiers for both.

2092 The issuing CA SHALL document in its Certification Practice Statement that the Certificates it issues
2093 containing the specified policy identifier(s) are managed in accordance with the CA/Browser Forum
2094 Baseline Requirements and this Certificate Policy.

2095 **7.1.7 Usage of Policy Constraints extension**

2096 Subordinate CAs MAY assert policy constraints in the CA certificates.

2097 **7.1.8 Policy qualifiers syntax and semantics**

2098 Certificates issued under this CP MAY contain policy qualifiers.

2099 **7.1.9 Processing semantics for the critical Certificate Policies extension**

2100 Certificates issued under this policy SHALL NOT contain a critical certificate policies extension.

2101 **7.2 CRL profile**

2102 **7.2.1 Version number(s)**

2103 The CAs SHALL issue X.509 Version two (2) CRLs.

2104 **7.2.2 CRL and CRL entry extensions**

2105 **a. reasonCode (required)**

2106 **Required/Optional:** Required

2107 This entry extension SHALL be present. The reasonCode value SHALL be populated in accordance with

2108 Section 4.9.1 for revocation reasons encompassing Key Compromise (reasonCode: keyCompromise) or
2109 CA Compromise (reasonCode: cACompromise).

2110 **7.3 OCSF profile**

2111 **7.3.1 Version number(s)**

2112 OCSF Responders operated under this policy shall use OCSF version 1.

2113 **7.3.2 OCSF extensions**

2114 This section specifies the additional requirements for Certificate contents for Online Certificate Status
2115 Protocol certificates, and extensions for OCSF status server extension and responses.

2116 **a. certificatePolicies (required)**

2117 **Required/Optional:** Required

2118 This extension SHALL be present and SHALL NOT be marked critical.

2119 **certificatePolicies:policyIdentifier (required)**

2120 **Required/Optional:** Required

2121 The certificate SHALL include at least one certificate policy OID defined or listed in Section 1.2 of this
2122 CP and SHALL include all the certificate policy OIDs for all certificates issued by the Issuing CA and
2123 covered by the OCSF responses

2124 **certificatePolicies:policyQualifiers:policyQualifierId (optional)**

2125 **Required/Optional:** Optional

2126 The extension SHOULD be present and is Recommended.

- 2127 • id-qt 1 [RFC 5280].

2128 **certificatePolicies:policyQualifiers:qualifier:cPSuri (optional)**

2129 **Required/Optional:** Optional

2130 HTTP URL for the Subordinate CA's Certification Practice Statement, Relying Party Agreement or other
2131 pointer to online information provided by the CA.

2132 **b. authorityInformationAccess (required)**

2133 **Required/Optional:** Required

2134 This extension SHALL be present. It SHALL NOT be marked critical, and it SHALL contain the HTTP
2135 URL of the Issuing CA's OCSF responder (accessMethod = 1.3.6.1.5.5.7.48.1). It SHALL also contain
2136 the HTTP URL of the Issuing CA's certificate (accessMethod = 1.3.6.1.5.5.7.48.2).

2137 **c. basicConstraints**

2138 **Required/Optional/Prohibited:** Prohibited

2139 This extension SHALL NOT be present.

2140 **d. keyUsage (required)**

2141 **Required/Optional:** Required

2142 This extension SHALL be present. It SHALL be marked critical.

2143 Certificates used for signing certificate status services (online certificate status protocol) SHALL include
2144 the value digitalSignature.

2145 Other values SHALL NOT be present.

2146 **e. extKeyUsage (required)**

2147 **Required/Optional:** Required

2148 This extension SHALL be present. It SHALL be marked critical.

2149 It SHALL contain the value id-kp-OCSPSigning {1 3 6 1 5 5 7 3 9}.

2150 Other values SHALL NOT be present.

8. COMPLIANCE AUDIT AND OTHER ASSESSMENTS

The CA SHALL at all times:

1. Issue Certificates and operate its PKI in accordance with all law applicable to its business and the Certificates it issues in every jurisdiction in which it operates;
2. Comply with these Requirements;
3. Comply with the audit requirements set forth in this section; and
4. Be licensed as a CA in each jurisdiction where it operates, if licensing is required by the law of such jurisdiction for the issuance of Certificates.

8.1 Frequency or circumstances of assessment

The Certificate Authorities (X.509v3 basicConstraints extension, with the cA boolean set to true) operated under this Certificate Policy are Technically Constrained in line with section 7.1.5. They are audited in line with section 8.7.

The period during which the CA issues Certificates SHALL be divided into an unbroken sequence of audit periods. An audit period MUST NOT exceed one year in duration.

Before issuing Publicly-Trusted Certificates, any CA SHALL successfully complete a point-in-time readiness assessment performed in accordance with applicable standards under one of the audit schemes listed in Section 8.1. The point-in-time readiness assessment SHALL be completed no earlier than twelve (12) months prior to issuing Publicly-Trusted Certificates and SHALL be followed by a complete audit under such scheme within ninety (90) days of issuing the first Publicly-Trusted Certificate

8.2 Identity/qualifications of assessor

The CA's audit SHALL be performed by a Qualified Auditor. A Qualified Auditor means a natural person, Legal Entity, or group of natural persons or Legal Entities that collectively possess the following qualifications and skills:

1. Independence from the subject of the audit;
2. The ability to conduct an audit that addresses the criteria specified in an Eligible Audit Scheme (see Section 8.1);
3. Employs individuals who have proficiency in examining Public Key Infrastructure technology, information security tools and techniques, information technology and security auditing, and the third-party attestation function;
4. (For audits conducted in accordance with the WebTrust standard) licensed by WebTrust;
5. Bound by law, government regulation, or professional code of ethics; and
6. Except in the case of an Internal Government Auditing Agency, maintains Professional Liability/Errors & Omissions insurance with policy limits of at least one million US dollars in coverage.

8.3 Assessor's relationship to assessed entity

The compliance auditor either shall be a private firm that is independent from the entities (CA and RAs) being audited, or it shall be sufficiently organizationally separated from those entities to provide an unbiased, independent evaluation. An example of the latter situation may be an Federal agency Inspector General. To insure independence and objectivity, the compliance auditor may not have served the entity in developing or maintaining the entity's CA Facility or certificate practices statement. The FPKI Policy Authority shall determine whether a compliance auditor meets this requirement.

The operating Agency and Management Authority of each CA is responsible for identifying and engaging a qualified auditor.

8.4 Topics covered by assessment

The CA SHALL undergo an audit in accordance with one of the following schemes:

1. WebTrust for Certification Authorities v2.0;
2. A national scheme that audits conformance to ETSI TS 102 042 / ETSI EN 319 411-1; or

Whichever scheme is chosen, it SHALL incorporate periodic monitoring and/or accountability procedures to ensure that its audits continue to be conducted in accordance with the requirements of the scheme.

The audit SHALL be conducted by a Qualified Auditor, as specified in Section 8.3.

There is no Delegated Third Party allowed under this Certificate Policy.

8.5 Actions taken as a result of deficiency

When the compliance auditor finds a discrepancy between the requirements of this CP or the stipulations in the CPS and the design, operation, or maintenance of the CAs, the following actions shall be performed: • The compliance auditor shall note the discrepancy; • The compliance auditor shall notify the responsible party promptly; and • The party responsible for correcting the discrepancy will propose a remedy, including expected time for completion, to the FPKI Policy Authority.

Depending upon the nature and severity of the discrepancy, and how quickly it can be corrected, the FPKI Policy Authority may decide to temporarily halt operation of the CA or RA, to revoke a certificate issued to the CA or RA, or take other actions it deems appropriate. A compliance audit may be required to confirm the implementation and effectiveness of the remedy.

8.6 Communication of results

The Audit Report SHALL state explicitly that it covers the relevant systems and processes used in the issuance of all Certificates that assert one or more of the policy identifiers listed in Section 7.1.6.1. The CA SHALL make the Audit Report publicly available. The CA is not required to make publicly available any general audit findings that do not impact the overall audit opinion. The CA SHOULD make its Audit Report publicly available no later than three months after the end of the audit period. In the event of a

2219 delay greater than three months, and if so requested by an Application Software Supplier, the CA SHALL
2220 provide an explanatory letter signed by the Qualified Auditor.

2221 **8.7 Self-Audits**

2222 During the period in which the CA issues Certificates, the CA SHALL monitor adherence to its
2223 Certificate Policy, Certification Practice Statement and these Requirements and strictly control its service
2224 quality by performing self audits on at least a quarterly basis against a randomly selected sample of the
2225 greater of one certificate or at least three percent of the Certificates issued by it during the period
2226 commencing immediately after the previous self-audit sample was taken.

2227 During the period in which a Technically Constrained Subordinate CA issues Certificates, the CA which
2228 signed the Subordinate CA SHALL monitor adherence to the this Certificate Policy and the Subordinate
2229 CA's Certification Practice Statement. On at least a quarterly basis, against a randomly selected sample of
2230 the greater of one certificate or at least three percent of the Certificates issued by the Subordinate CA,
2231 during the period commencing immediately after the previous audit sample was taken, the CA shall
2232 ensure all applicable CP are met.

2233 There is no Delegated Third Party allowed under this Certificate Policy.

2234 **9. OTHER BUSINESS AND LEGAL** 2235 **MATTERS**

2236 This section contains the CA / Browser Forum Baseline Requirements and has not been modified.
2237 Additions to Business and Legal Matters to address Application Trusted Root Program requirements and
2238 U.S. Government provisions to meet public law requirements are under review and not included in this
2239 draft.

2240 **9.1 Fees**

2241 **9.1.1 Certificate issuance or renewal fees**

2242 **9.1.2 Certificate access fees**

2243 **9.1.3 Revocation or status information access fees**

2244 **9.1.4 Fees for other services**

2245 **9.1.5 Refund policy**

2246 **9.2 Financial responsibility**

2247 **9.2.1 Insurance coverage**

2248 **9.2.2 Other assets**

2249 **9.2.3 Insurance or warranty coverage for end-entities**

2250 **9.3 Confidentiality of business information**

2251 **9.3.1 Scope of confidential information**

2252 **9.3.2 Information not within the scope of confidential information**

2253 **9.3.3 Responsibility to protect confidential information**

2254 **9.4 Privacy of personal information**

2255 **9.4.1 Privacy plan**

2256 **9.4.2 Information treated as private**

2257 **9.4.3 Information not deemed private**

2258 **9.4.4 Responsibility to protect private information**

2259 **9.4.5 Notice and consent to use private information**

2260 **9.4.6 Disclosure pursuant to judicial or administrative process**

2261 **9.4.7 Other information disclosure circumstances**

2262 **9.5 Intellectual property rights**

2263 **9.6 Representations and warranties**

2264 **9.6.1 CA representations and warranties**

2265 By issuing a Certificate, the CA makes the certificate warranties listed herein to the following Certificate
2266 Beneficiaries:

- 2267 1. The Subscriber that is a party to the Subscriber Agreement or Terms of Use for the Certificate;
2268 2. All Application Software Suppliers with whom the Root CA has entered into a contract for
2269 inclusion of its Root Certificate in software distributed by such Application Software Supplier;
2270 and
2271 3. All Relying Parties who reasonably rely on a Valid Certificate. The CA represents and warrants
2272 to the Certificate Beneficiaries that, during the period when the Certificate is valid, the CA has
2273 complied with these Requirements and its Certificate Policy and/or Certification Practice
2274 Statement in issuing and managing the Certificate.

2275 The Certificate Warranties specifically include, but are not limited to, the following:

- 2276 1. **Right to Use Domain Name or IP Address:** That, at the time of issuance, the CA (i)
2277 implemented a procedure for verifying that the Applicant either had the right to use, or had
2278 control of, the Domain Name(s) and IP address(es) listed in the Certificate's subject field and
2279 subjectAltName extension (or, only in the case of Domain Names, was delegated such right or
2280 control by someone who had such right to use or control); (ii) followed the procedure when
2281 issuing the Certificate; and (iii) accurately described the procedure in the CA's Certificate Policy
2282 and/or Certification Practice Statement;
2283 2. **Authorization for Certificate:** That, at the time of issuance, the CA (i) implemented a procedure
2284 for verifying that the Subject authorized the issuance of the Certificate and that the Applicant
2285 Representative is authorized to request the Certificate on behalf of the Subject; (ii) followed the
2286 procedure when issuing the Certificate; and (iii) accurately described the procedure in the CA's
2287 Certificate Policy and/or Certification Practice Statement;
2288 3. **Accuracy of Information:** That, at the time of issuance, the CA (i) implemented a procedure for
2289 verifying the accuracy of all of the information contained in the Certificate (with the exception of
2290 the subject:organizationalUnitName attribute); (ii) followed the procedure when issuing the
2291 Certificate; and (iii) accurately described the procedure in the CA's Certificate Policy and/or
2292 Certification Practice Statement;

- 2293 4. **No Misleading Information:** That, at the time of issuance, the CA (i) implemented a procedure
2294 for reducing the likelihood that the information contained in the Certificate's
2295 subject:organizationalUnitName attribute would be misleading; (ii) followed the procedure when
2296 issuing the Certificate; and (iii) accurately described the procedure in the CA's Certificate Policy
2297 and/or Certification Practice Statement;
- 2298 5. **Identity of Applicant:** That, if the Certificate contains Subject Identity Information, the CA (i)
2299 implemented a procedure to verify the identity of the Applicant in accordance with Sections 3.2
2300 and 11.2; (ii) followed the procedure when issuing the Certificate; and (iii) accurately described
2301 the procedure in the CA's Certificate Policy and/or Certification Practice Statement;
- 2302 6. **Subscriber Agreement:** That, if the CA and Subscriber are not Affiliated, the Subscriber and CA
2303 are parties to a legally valid and enforceable Subscriber Agreement that satisfies these
2304 Requirements, or, if the CA and Subscriber are the same entity or are Affiliated, the Applicant
2305 Representative acknowledged the Terms of Use;
- 2306 7. **Status:** That the CA maintains a 24 x 7 publicly-accessible Repository with current information
2307 regarding the status (valid or revoked) of all unexpired Certificates; and
- 2308 8. **Revocation:** That the CA will revoke the Certificate for any of the reasons specified in these
2309 Requirements.

2310 The Root CA SHALL be responsible for the performance and warranties of the Subordinate CA, for the
2311 Subordinate CA's compliance with these Requirements, and for all liabilities and indemnification
2312 obligations of the Subordinate CA under these Requirements, as if the Root CA were the Subordinate CA
2313 issuing the Certificates

2314 9.6.2 RA representations and warranties

2315 No stipulation.

2316 9.6.3 Subscriber representations and warranties

2317 The CA SHALL require, as part of the Subscriber Agreement or Terms of Use, that the Applicant make
2318 the commitments and warranties in this section for the benefit of the CA and the Certificate Beneficiaries.

2319 Prior to the issuance of a Certificate, the CA SHALL obtain, for the express benefit of the CA and the
2320 Certificate Beneficiaries, either:

- 2321 1. The Applicant's agreement to the Subscriber Agreement with the CA, or
2322 2. The Applicant's acknowledgement of the Terms of Use.

2323 The CA SHALL implement a process to ensure that each Subscriber Agreement or Terms of Use is
2324 legally enforceable against the Applicant. In either case, the Agreement MUST apply to the Certificate to
2325 be issued pursuant to the certificate request. The CA MAY use an electronic or "click-through"
2326 Agreement provided that the CA has determined that such agreements are legally enforceable. A separate
2327 Agreement MAY be used for each certificate request, or a single Agreement MAY be used to cover
2328 multiple future certificate requests and the resulting Certificates, so long as each Certificate that the CA
2329 issues to the Applicant is clearly covered by that Subscriber Agreement or Terms of Use.

2330 The Subscriber Agreement or Terms of Use MUST contain provisions imposing on the Applicant itself
2331 (or made by the Applicant on behalf of its principal or agent under a subcontractor or hosting service
2332 relationship) the following obligations and warranties:

1. **Accuracy of Information:** An obligation and warranty to provide accurate and complete information at all times to the CA, both in the certificate request and as otherwise requested by the CA in connection with the issuance of the Certificate(s) to be supplied by the CA;
2. **Protection of Private Key:** An obligation and warranty by the Applicant to take all reasonable measures to assure control of, keep confidential, and properly protect at all times the Private Key that corresponds to the Public Key to be included in the requested Certificate(s) (and any associated activation data or device, e.g. password or token);
3. **Acceptance of Certificate:** An obligation and warranty that the Subscriber will review and verify the Certificate contents for accuracy;
4. **Use of Certificate:** An obligation and warranty to install the Certificate only on servers that are accessible at the subjectAltName(s) listed in the Certificate, and to use the Certificate solely in compliance with all applicable laws and solely in accordance with the Subscriber Agreement or Terms of Use;
5. **Reporting and Revocation:** An obligation and warranty to: (a) promptly request revocation of the Certificate, and cease using it and its associated Private Key, if there is any actual or suspected misuse or compromise of the Subscriber's Private Key associated with the Public Key included in the Certificate, and (b) promptly request revocation of the Certificate, and cease using it, if any information in the Certificate is or becomes incorrect or inaccurate;
6. **Termination of Use of Certificate:** An obligation and warranty to promptly cease all use of the Private Key corresponding to the Public Key included in the Certificate upon revocation of that Certificate for reasons of Key Compromise.
7. **Responsiveness:** An obligation to respond to the CA's instructions concerning Key Compromise or Certificate misuse within a specified time period.
8. **Acknowledgment and Acceptance:** An acknowledgment and acceptance that the CA is entitled to revoke the certificate immediately if the Applicant were to violate the terms of the Subscriber Agreement or Terms of Use or if the CA discovers that the Certificate is being used to enable criminal activities such as phishing attacks, fraud, or the distribution of malware.

9.6.4 Relying party representations and warranties

9.6.5 Representations and warranties of other participants

9.7 Disclaimers of warranties

9.8 Limitations of liability

For delegated tasks, the CA and any Delegated Third Party MAY allocate liability between themselves contractually as they determine, but the CA SHALL remain fully responsible for the performance of all parties in accordance with these Requirements, as if the tasks had not been delegated.

If the CA has issued and managed the Certificate in compliance with these Requirements and its Certificate Policy and/or Certification Practice Statement, the CA MAY disclaim liability to the Certificate Beneficiaries or any other third parties for any losses suffered as a result of use or reliance on such Certificate beyond those specified in the CA's Certificate Policy and/or Certification Practice Statement. If the CA has not issued or managed the Certificate in compliance with these Requirements and its Certificate Policy and/or Certification Practice Statement, the CA MAY seek to limit its liability to the Subscriber and to Relying Parties, regardless of the cause of action or legal theory involved, for any and all claims, losses or damages suffered as a result of the use or reliance on such Certificate by any

2375 appropriate means that the CA desires. If the CA chooses to limit its liability for Certificates that are not
2376 issued or managed in compliance with these Requirements or its Certificate Policy and/or Certification
2377 Practice Statement, then the CA SHALL include the limitations on liability in the CA's Certificate Policy
2378 and/or Certification Practice Statement.

2379 **9.9 Indemnities**

2380 Notwithstanding any limitations on its liability to Subscribers and Relying Parties, the CA understands
2381 and acknowledges that the Application Software Suppliers who have a Root Certificate distribution
2382 agreement in place with the Root CA do not assume any obligation or potential liability of the CA under
2383 these Requirements or that otherwise might exist because of the issuance or maintenance of Certificates
2384 or reliance thereon by Relying Parties or others. Thus, except in the case where the CA is a government
2385 entity, the CA SHALL defend, indemnify, and hold harmless each Application Software Supplier for any
2386 and all claims, damages, and losses suffered by such Application Software Supplier related to a
2387 Certificate issued by the CA, regardless of the cause of action or legal theory involved. This does not
2388 apply, however, to any claim, damages, or loss suffered by such Application Software Supplier related to
2389 a Certificate issued by the CA where such claim, damage, or loss was directly caused by such Application
2390 Software Supplier's software displaying as not trustworthy a Certificate that is still valid, or displaying as
2391 trustworthy: (1) a Certificate that has expired, or (2) a Certificate that has been revoked (but only in cases
2392 where the revocation status is currently available from the CA online, and the application software either
2393 failed to check such status or ignored an indication of revoked status).

2394 **9.10 Term and termination**

2395 **9.10.1 Term**

2396 **9.10.2 Termination**

2397 **9.10.3 Effect of termination and survival**

2398 **9.11 Individual notices and communications with** 2399 **participants**

2400 The FPKIPA will be notified of any change in management or operational control of a CA.

2401 **9.12 Amendments**

2402 **9.12.1 Procedure for amendment**

2403 **9.12.2 Notification mechanism and period**

2404 **9.12.3 Circumstances under which OID must be changed**

2405 **9.13 Dispute resolution provisions**

2406 **9.14 Governing law**

2407 **9.15 Compliance with applicable law**

2408 **9.16 Miscellaneous provisions**

2409 **9.16.1 Entire agreement**

2410 **9.16.2 Assignment**

2411 **9.16.3 Severability**

2412 In the event of a conflict between these Requirements and a law, regulation or government order
2413 (hereinafter ‘Law’) of any jurisdiction in which a CA operates or issues certificates, a CA MAY modify
2414 any conflicting requirement to the minimum extent necessary to make the requirement valid and legal in
2415 the jurisdiction. This applies only to operations or certificate issuances that are subject to that Law. In
2416 such event, the CA SHALL immediately (and prior to issuing a certificate under the modified
2417 requirement) include in Section 9.16.3 of the CA’s CPS a detailed reference to the Law requiring a
2418 modification of these Requirements under this section, and the specific modification to these
2419 Requirements implemented by the CA.

2420 The CA MUST also (prior to issuing a certificate under the modified requirement) notify the CA/Browser
2421 Forum of the relevant information newly added to its CPS by sending a message to
2422 questions@cabforum.org and receiving confirmation that it has been posted to the Public Mailing List
2423 and is indexed in the Public Mail Archives available at <https://cabforum.org/pipermail/public/> (or such
2424 other email addresses and links as the Forum may designate), so that the CA/Browser Forum may
2425 consider possible revisions to these Requirements accordingly.

2426 Any modification to CA practice enabled under this section MUST be discontinued if and when the Law
2427 no longer applies, or these Requirements are modified to make it possible to comply with both them and
2428 the Law simultaneously. An appropriate change in practice, modification to the CA’s CPS and a notice to
2429 the CA/Browser Forum, as outlined above, MUST be made within 90 days.

2430 **9.16.4 Enforcement (attorneys’ fees and waiver of rights)**

2431 **9.16.5 Force Majeure**

2432 **9.17 Other provisions**